ICS 35.030
CCS L 80

中华人民共和国国家标准

GB/T 30279—202X
代替 GB/T 30279—2020

网络安全技术 网络安全漏洞分类分级指南

CyberSecurity technology—Guidelines for categorization and classification of cybersecurity vulnerability

（征求意见稿）

XXXX-XX-XX 发布　　XXXX-XX-XX 实施

国家市场监督管理总局
国家标准化管理委员会　发布

目　　次

前言 II
1 范围 1
2 规范性引用文件 1
3 术语和定义 1
4 缩略语 1
5 网络安全漏洞分类 2
5.1 概述 2
5.2 基于缺陷的漏洞分类 2
5.3 基于影响的漏洞分类 7
6 网络安全漏洞分级 12
6.1 概述 12
6.2 网络安全漏洞分级指标 12
6.3 网络安全漏洞分级方法 19
附录A （规范性） 可利用性评分表 20
附录B （规范性） 影响程度评分表 24
附录C （规范性） 环境因素评分表 25
附录D （规范性） 漏洞技术分级表 32
附录E （规范性） 漏洞综合分级表 33
附录F （资料性） 漏洞分类示例 34
附录G （资料性） 漏洞分级示例 36
附录H （资料性） 漏洞分级兼容性说明 47
附录I （资料性） 漏洞分级兼容性说明 51
参考文献 52

前　言

本文件按照GB/T 1.1—2020《标准化工作导则　第1部分：标准化文件的结构和起草规则》的规定起草。

本文件代替GB/T 30279—2020《信息安全技术　网络安全漏洞分类分级指南》，与GB/T 30279—2020相比，除结构调整和编辑性改动外，主要技术变化如下：

a) 更改了“网络安全漏洞分类”，某一漏洞可按照需要选择一种或两种漏洞分类维度，也可归为一种或多种漏洞类型（见5.1，2020年版的5.1），旨在解决分类方法对不同使用场景的适配性问题；

b) 增加了“基于影响的漏洞分类”，将原本基于缺陷的单一漏洞类型，拓展为“基于缺陷的漏洞分类”（见5.2，2020年版的第5章）和“基于影响的漏洞分类”（见5.3）双重分类框架，旨在解决分类维度对不同使用场景的适配性问题；

c) 增加了“人工智能模型训练推理问题”分类（见5.2.10），旨在解决漏洞类型对人工智能前沿技术领域的覆盖问题；

d) 更改了“网络安全漏洞分级”，将原标准的技术分级和综合分级修订为两个独立的分级结果（见6.1、6.3，2020年版的6.1、6.3），旨在解决分级方法对不同使用场景的适配性问题；

e) 增加了“攻击复杂度”“间接影响”“潜在损失”“防护能力”等分级指标（见6.2.1、6.2.2、6.2.3，2020年版的6.2.1、6.2.2、6.2.3），旨在解决分级指标对不同使用场景的适配性问题；

f) 增加了“漏洞分类示例”和“漏洞分级示例”（见附录F、附录G），旨在解决不同使用对象分类分级操作指引问题；

g) 增加了“漏洞分类兼容性说明”和“漏洞分级兼容性说明”（见附录H、附录I），旨在解决标准修订后使用对象在衔接过程中可能存在的适配性问题。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由全国网络安全标准化技术委员会（SAC/TC 260）提出并归口。

本文件起草单位：中国信息安全测评中心、中国信息通信研究院、国家信息技术安全研究中心、国家计算机网络应急技术处理协调中心、公安部第一研究所、公安部第三研究所、国家工业信息安全发展研究中心、浙江御安信息技术有限公司、启明星辰信息技术集团股份有限公司、南方电网数字电网集团有限公司网络安全运行调度控制中心、南方电网科学研究院有限责任公司、南方电网数字电网集团信息通信科技有限公司、国网新疆电力有限公司电力科学研究院、中通服咨询设计研究院有限公司、中国移动通信集团有限公司、中国民生银行股份有限公司、杭州安恒信息技术股份有限公司、中兴通讯股份有限公司、华为技术有限公司、北京神州绿盟科技有限公司、中国联合网络通信集团有限公司、浙江大华技术股份有限公司、北京长亭科技有限公司、天翼安全科技有限公司、北京微步在线科技有限公司、杭州迪普科技股份有限公司、深信服科技股份有限公司、广州市昊恒信息科技有限公司、中国信息安全测评中心华中测评中心、上海斗象信息科技有限公司、北京天融信网络安全技术有限公司、国电南京自动化股份有限公司、中国电子信息产业集团有限公司第六研究所、瀚高基础软件股份有限公司、西安邮电大学、浪潮电子信息产业股份有限公司、中电科金仓（北京）科技股份有限公司、海光信息技术股份有限公司、北京自然原数科技有限公司、浙江鹏信信息科技股份有限公司、亚信科技（成都）有限公司、北京中测安华科技有限公司、中国软件评测中心、国核自仪系统工程有限公司。

本文件主要起草人：杨诗雨、宋创创、刘双喜、姚佳明、马洋洋、司成祥、张增波、宋铮、王诗蕊、封荣、崔牧凡、赵嘉伟、李晔、方硕、郭银锋、买提赛地·买吐送、丁斌、刘欣、毕乐宇、邹洪、李峰、

邓萍萍、刘钊、李天磊、廖喜君、夏云浩、吴黎明、张睿、聂晓帆、应天元、杨坤、毛东峰、温佳宝、陈露姹、王振兴、吴文超、魏浩、徐钟豪、王媛媛、刘臻、赵云龙、冯明冉、张勇、张忠伟、宋瑞、展恩果、江晶、艾舒欣、史光庭、康欣元、秦晓磊、杨鑫。

本文件及其所代替文件的历次版本发布情况为：

——GB/T 30279—2013；

——GB/T 33561—2017；

——GB/T 30279—2020。

网络安全技术　网络安全漏洞分类分级指南

1　范围

本文件给出了网络安全漏洞（简称“漏洞”）的分类方式、分级指标及分级方法指南。

本文件适用于网络产品和服务的提供者、网络运营者、漏洞收录组织、漏洞应急组织，在漏洞信息管理、网络产品生产、技术研发、系统运营等相关活动中，开展基于软件系统、硬件架构或软硬结合体的漏洞分类、漏洞危害等级评估等工作。

2　规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

GB/T 20984—2022　信息安全技术　信息安全风险评估方法

GB/T 25069—2022　信息安全技术　术语

GB/T 28458—2020　信息安全技术　网络安全漏洞标识与描述规范

GB/T 30276—2020　信息安全技术　网络安全漏洞管理规范

3　术语和定义

GB/T 25069、GB/T 20984、GB/T 28458、GB/T 30276界定的以及下列术语和定义适用于本文件。

3.1

网络安全漏洞 cybersecurity vulnerability

网络产品和服务在需求分析、设计、实现、配置、测试、运行、维护等过程中，无意或有意产生的、有可能被利用的缺陷或薄弱点。

注：这些缺陷或薄弱点以不同形式存在于网络产品和服务的各个层次和环节中，一旦被恶意主体所利用，就会对网络产品和服务的安全造成损害，从而影响其正常运行。

[来源：GB/T 28458-2020，3.1]

3.2

受影响产品或服务 impacted component

漏洞所存在的产品或服务的详细信息，包括供应商、名称、版本号等内容。对于共用中间件或者组件的漏洞，受其影响的相关产品或服务信息均可列出。

[来源：GB/T 28458-2020，5.3.8]

4　缩略语

下列缩略语适用于本文件。

BGP：边界网关协议（Border Gateway Protocol）

CSRF：跨站请求伪造（Cross-site request forgery）

DDoS：分布式拒绝服务（Distributed Denial of Service attack)

DoS：拒绝服务（Denial of service）

EDR：端点检测和响应（Endpoint Detection and Response）

EXP：漏洞利用（EXPloit）

I/O：输入/输出（Input/Output）

LCE：本地代码执行（Local Code Execution）

POC：概念验证（Proof of Concept）

RCE：远程代码执行（Remote Code Execution）

Seccomp：Linux 系统安全特性（Secure computing）

SQL：结构化查询语言（Structured Query Language)

UAC：用户账户控制（User Account Control）

XSS：跨站脚本（Cross Site Scripting）

5 网络安全漏洞分类

5.1 概述

网络安全漏洞分类是基于漏洞的技术特征对漏洞进行的划分，不同的划分者出于不同的目标与场景，会采用不同的漏洞分类维度。本文件基于造成漏洞的软硬件缺陷或触发漏洞的危害影响两种维度对漏洞进行类别划分。

基于缺陷的漏洞分类，主要适用于网络产品和服务的研发与生产环节，区分漏洞产生的原因，用于定位和识别漏洞形成的技术根源，以支持漏洞修补活动。基于缺陷的漏洞分类合计11个一级分类、35个二级分类。

基于影响的漏洞分类，主要适用于网络产品和服务的运营环节，区分漏洞被利用的后果，用于从风险影响角度评估漏洞的严重程度，以支持漏洞消控活动。基于影响的漏洞分类合计6个一级分类、25个二级分类。

网络产品和服务的提供者、网络运营者、漏洞收录组织、漏洞应急组织在漏洞信息管理时，可按照需要选择一种或多种漏洞分类维度，即当漏洞具备多种缺陷特征、或可能造成多种危害影响时，可将其归入多个相应类别。在进行具体漏洞分类时，遵循“二级分类优先”原则，即优先将漏洞归入可匹配的二级子类型，若无对应的二级子类型，则将其归入其所属的一级分类。

5.2 基于缺陷的漏洞分类

基于缺陷的漏洞分类合计11个一级分类、35个二级分类，漏洞分类导图如图1所示。

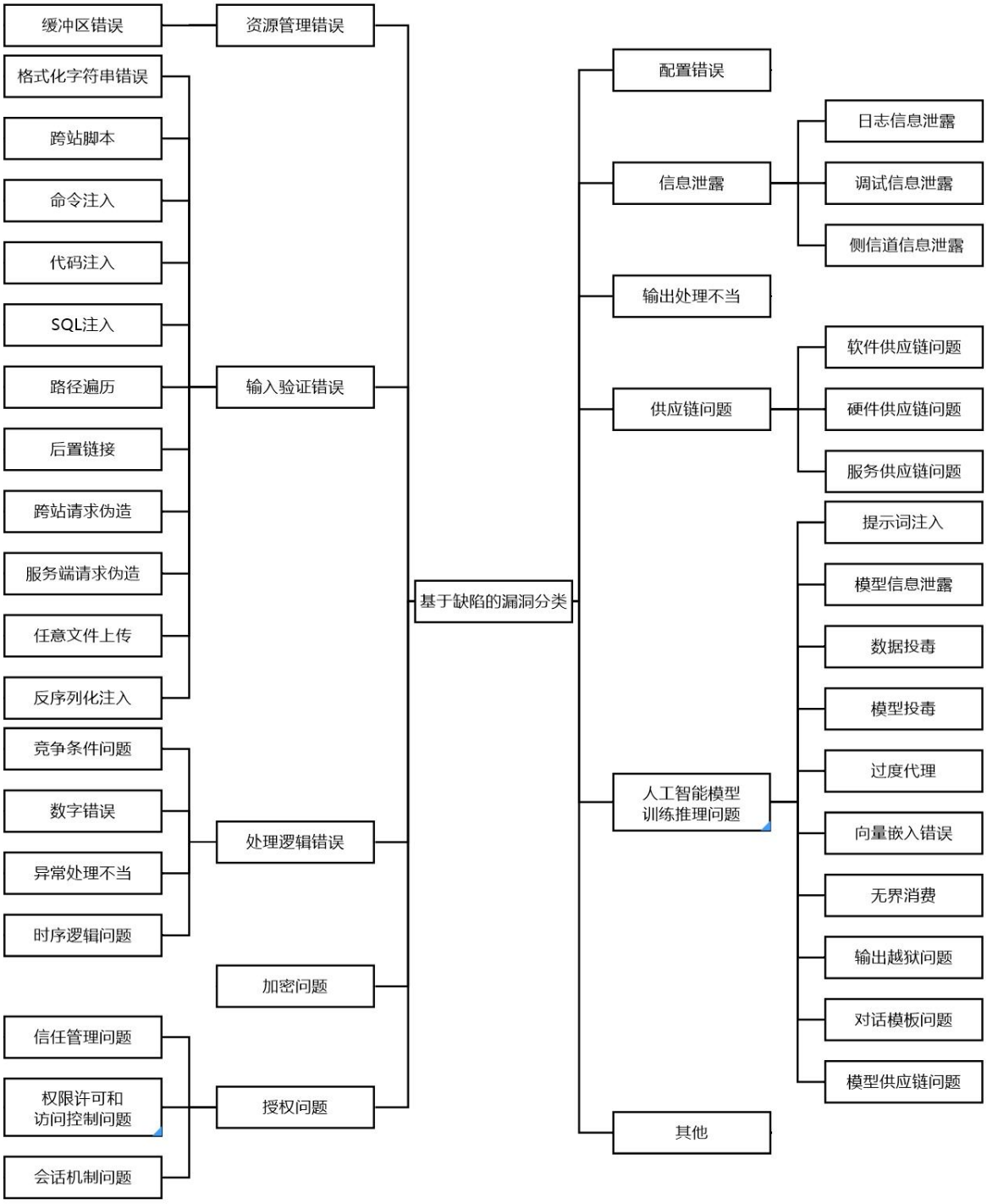


图1　基于缺陷的漏洞分类图

5.2.1　资源管理错误

资源管理错误漏洞指因对系统资源（如内存、磁盘空间、文件句柄、网络连接和CPU使用率等）的错误管理导致的安全问题。

5.2.1.1 缓冲区错误

缓冲区错误漏洞指在内存上执行操作时，因缺少正确的边界数据验证管理，导致在其相关联的其他内存位置上执行了错误的读写操作，如缓冲区溢出、堆栈溢出等安全问题。

5.2.2 输入验证错误

输入验证错误漏洞指因对输入的数据缺少正确的验证而产生的漏洞。

5.2.2.1 格式化字符串错误

格式化字符串错误漏洞指接收外部格式化字符串作为参数时，因参数类型、数量等过滤不严格导致的漏洞，导致代码执行错误。

5.2.2.2 跨站脚本

跨站脚本漏洞指在WEB应用中，因缺少对客户端数据的正确验证，导致向其他客户端提供错误执行代码。

5.2.2.3 命令注入

命令注入漏洞指在构造可执行命令过程中，因未正确过滤其中的特殊元素，导致生成非预期的可执行命令。

5.2.2.4 代码注入

代码注入漏洞指在通过外部输入数据构造代码段的过程中，因未正确过滤其中的特殊元素，导致生成了错误的代码段，修改了网络产品和服务的预期的执行控制流。

5.2.2.5 SQL 注入

SQL注入漏洞指在基于数据库的应用中，因缺少对构成SQL语句的外部输入数据的验证，导致生成并执行了错误的SQL语句。

5.2.2.6 路径遍历

路径遍历漏洞指因未能正确地过滤资源或文件路径中的特殊元素，导致访问受限目录之外的位置。

5.2.2.7 后置链接

后置链接漏洞指在使用文件名访问文件时，因未正确过滤表示非预期资源的链接或者快捷方式的文件名，导致访问了错误的文件路径。

5.2.2.8 跨站请求伪造

跨站请求伪造漏洞指在WEB应用中，因未充分验证请求是否来自可信用户，导致受欺骗的客户端向服务器发送非预期的请求。

5.2.2.9 服务端请求伪造

服务端请求伪造漏洞指在WEB应用中，因未充分验证用户输入的访问地址参数，导致受欺骗的服务端发送非预期的请求。

5.2.2.10 任意文件上传

任意文件上传漏洞指因未对上传的文件类型、内容和存储路径等进行严格校验，导致上传非限定文件引发的安全问题。

5.2.2.11 反序列化注入

反序列化注入漏洞指在通过外部输入的序列化数据重建为对象的过程中，因未正确过滤其中的特殊元素，导致执行恶意代码逻辑，修改了网络产品和服务的预期执行控制流。

5.2.3 处理逻辑错误

处理逻辑错误漏洞指在设计实现过程中，因处理逻辑实现问题或分支覆盖不全面等原因造成。

5.2.3.1 竞争条件问题

竞争条件问题漏洞指因在并发运行环境中，一段并发代码需要互斥地访问共享资源时，因另一段代码在同一个时间窗口可以并发修改共享资源而导致的安全问题。

5.2.3.2 数字错误

数字错误漏洞指因未正确计算或转换所产生数字，导致的数值溢出、符号错误等安全问题。

5.2.3.3 异常处理不当

异常处理不当漏洞指在系统或程序的逻辑处理过程中，当遇到未预料的异常条件（如空指针解引用、资源异常等）时，由于缺乏充分的检查与处理机制，导致软件发生崩溃、退出或进入非预期状态。

5.2.3.4 时序逻辑问题

时序逻辑问题漏洞指在软硬件系统运行过程中，由于时序逻辑处理不当导致的安全问题。

5.2.4 加密问题

加密问题漏洞指未正确使用相关密码算法，导致的内容未正确加密、弱加密、明文存储敏感信息等安全问题。

5.2.5 授权问题

授权问题漏洞指在身份验证或权限分配过程中，因身份验证或授权机制缺陷导致的安全问题。

5.2.5.1 信任管理问题

信任管理问题漏洞指因缺乏有效的信任管理机制，导致受影响组件存在可被攻击者利用的默认密码或者硬编码密码、硬编码证书等安全问题。

5.2.5.2 权限许可和访问控制问题

权限许可和访问控制问题漏洞指因缺乏有效的权限许可和访问控制措施而导致的安全问题。

5.2.5.3 会话机制问题

会话机制问题漏洞指在身份认证过程中使用的会话机制存在缺陷，使会话凭证泄露或可预测，导致认证身份被劫持等安全问题。

5.2.6 配置错误

配置错误漏洞指网络产品和服务或组件在使用过程中因配置文件、配置参数或因默认不安全的配置状态而产生的安全问题。

5.2.7 信息泄露

信息泄露漏洞指在运行过程中，因配置等错误导致的受影响组件信息被非授权获取的漏洞。

5.2.7.1 日志信息泄露

日志信息泄露漏洞指因日志内容非正常输出导致的信息泄露。

5.2.7.2 调试信息泄露

调试信息泄露漏洞指在运行过程中因调试信息输出导致的信息泄露。

5.2.7.3 侧信道信息泄露

侧信道信息泄露漏洞指功耗、电磁辐射、I/O特性、运算频率、时耗等侧信道信息的变化导致的信息泄露。

5.2.8 输出处理不当

输出处理不当洞指网络产品或服务对输出数据未进行有效的处理导致的安全问题。

5.2.9 供应链问题

供应链问题漏洞指软硬件系统服务及相关数据的全生命周期中，因开源库、商业软件或硬件设备等第三方组件存在固有缺陷或供应链各环节安全管控缺失导致的安全问题。

5.2.9.1 软件供应链问题

软件供应链问题漏洞指在软件全生命周期内中，因开源组件、第三方库或商业软件等第三方组件存在固有缺陷导致的安全问题。

5.2.9.2 硬件供应链问题

硬件供应链问题漏洞指在硬件全生命周期内中，因固件、芯片或外设等第三方组件存在固有缺陷导致的安全问题。

5.2.9.3 服务供应链问题

服务供应链问题漏洞指在运维服务、数据服务等网络服务周期中，因准入审核不严、权限管理不当、开发或部署流程不规范等供应链各环节安全管控缺失导致的安全问题。

5.2.10 人工智能模型训练推理问题

人工智能模型训练推理问题漏洞指人工智能模型在训练、微调或者推理应用时产生的安全问题。

5.2.10.1 提示词注入

提示词注入漏洞指在人工智能模型应用中，因未正确识别和过滤输入的恶意指令或隐藏在外部数据源（如：检索文档）中的恶意指令，导致人工智能模型无法正确识别执行指令或模型行为被误导或被操纵。

5.2.10.2 模型信息泄露

模型信息泄露漏洞指人工智能模型在应用过程中对输出内容未进行有效过滤导致的信息泄露。

5.2.10.3 数据投毒

数据投毒漏洞指人工智能模型在训练或推理过程中，因数据集未进行有效清洗和安全验证，导致数据集中含有恶意数据，影响模型训练或推理，部署后模型出现错误行为。

5.2.10.4 模型投毒

模型投毒漏洞指人工智能模型在训练和应用过程中，因未对模型本身参数、代码或配置等进行有效防护，导致模型参数、代码或配置被篡改操控，使模型出现行为异常、功能受损或对下游系统利用等安全问题。

5.2.10.5 过度代理

过度代理漏洞指人工智能模型或其关联的代理组件因被授予过多的功能或过高的权限，导致其执行未经授权的操作。

5.2.10.6 向量嵌入错误

向量嵌入错误漏洞指人工智能模型在依赖向量嵌入来表示和处理信息时，因在向量生成、存储或检索方面被操纵利用，导致注入有害内容、操纵模型输出或访问敏感数据。

5.2.10.7 无界消费

无界消费漏洞指人工智能模型在推理过程中，因发送大量无用或精心设计的复杂请求，恶意消耗模型资源（如：计算资源、内存和API调用等），导致拒绝服务、成本增加和潜在的性能降级等安全问题。

5.2.10.8 输出越狱问题

输出越狱问题漏洞指人工智能模型在应用过程中，因模型的安全对齐机制或安全护栏存在缺陷，导致模型未能有效防止输出不安全、不合规内容（如：非法信息、虚假内容和敏感数据等）等安全问题。

5.2.10.9 对话模板问题

对话模板问题漏洞指人工智能模型在应用时，因对话模板实现不当，导致模型对话产生非预期结构输出，引起语料泄露、安全对齐失效等问题。

5.2.10.10 模型供应链问题

模型供应链问题漏洞指人工智能模型在部署、训练和应用过程中，引入的第三方软件、组件或训练数据存在安全问题，导致模型和部署平台存在安全问题。

5.2.11 其他

暂时无法将漏洞归入上述任何类别，或者没有足够充分的信息对其进行分类，漏洞细节未指明。

5.3 基于影响的漏洞分类

基于影响的漏洞分类合计6个一级分类、25个二级分类，漏洞分类导图如图2所示。

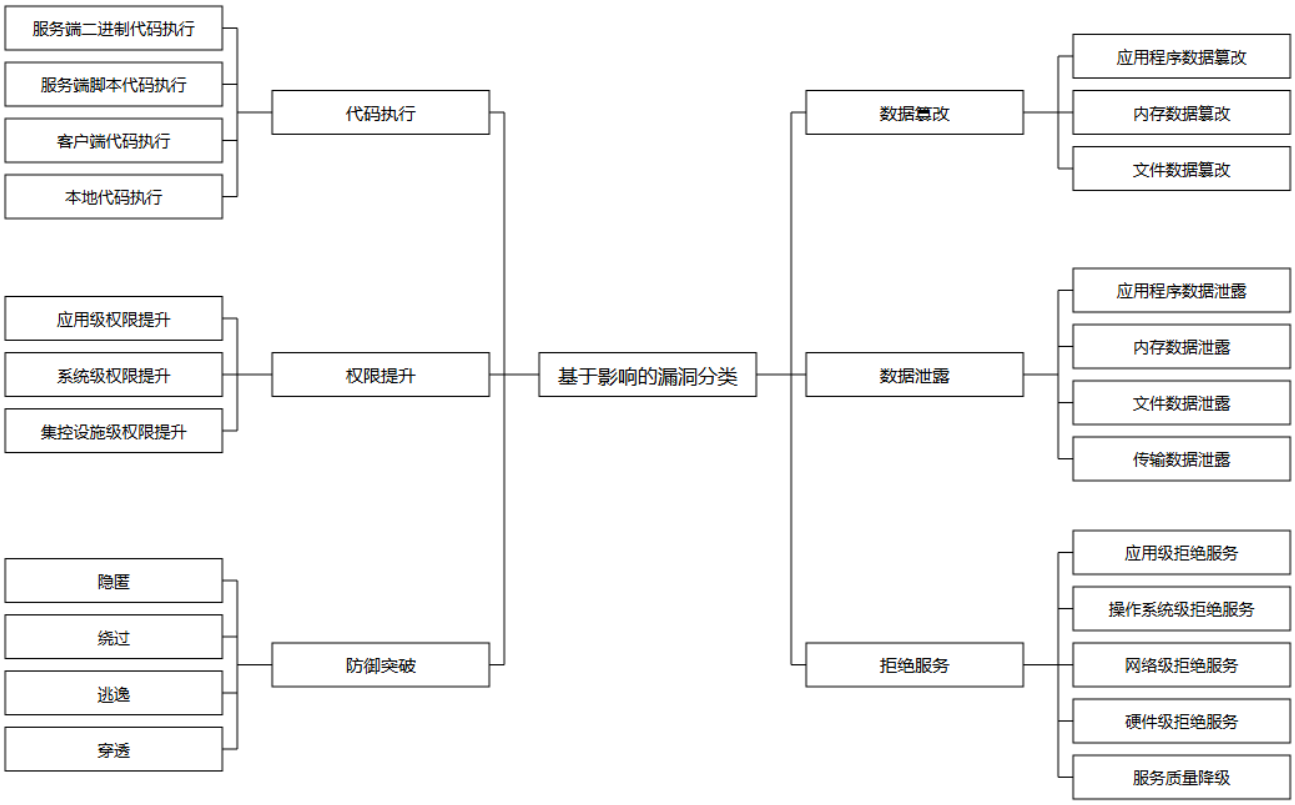


图2　基于影响的漏洞分类图

5.3.1　代码执行

代码执行漏洞指攻击者通过构造恶意载荷触发目标系统中的安全缺陷，成功劫持程序执行流程，使其在未授权的情况下执行攻击者指定的代码。典型利用后果是在目标系统的安全上下文内获得非预期的权限或资源访问能力。根据攻击者与目标系统的位置关系，主要分为远程代码执行（RCE）与本地代码执行（LCE）；其中远程代码执行可进一步按攻击方向分为服务端RCE与客户端RCE，按所利用漏洞的技术特性可分为基于二进制内存破坏的RCE和基于脚本引擎等解释执行环境的RCE。

5.3.1.1　服务端二进制代码执行

服务端二进制代码执行漏洞指攻击者通过网络远程利用服务端软件中存在的二进制类漏洞，精确操控内存数据劫持程序执行流，并植入并执行恶意代码（ShellCode），最终获得与目标服务进程等同的系统级权限。达成该危害效果的漏洞利用包括：缓冲区溢出、释放后重用等。

5.3.1.2　服务端脚本代码执行

服务端脚本代码执行漏洞指攻击者通过网络远程利用服务端WEB应用软件中存在的脚本类逻辑缺陷（如在PHP、JAVA、Python等语言处理动态内容时的逻辑缺陷），注入并执行由攻击者构造的恶意脚本代码，最终获得与目标WEB应用进程等同的系统级权限。达成该危害效果的漏洞利用包括：代码注入、命令注入、文件上传、反序列化等。

5.3.1.3　客户端代码执行

客户端代码执行漏洞指攻击者通过伪装或劫持服务器与客户端的正常交互连接，利用客户端软件（如浏览器、联网办公软件、VPN客户端等）中存在的脚本引擎缺陷、内容解析漏洞或内存破坏类漏洞，在客户端进程的安全上下文中执行由攻击者构造的恶意代码。达成该危害效果的漏洞利用包括：水坑攻击、跨站脚本、跨站请求伪造等。

5.3.1.4 本地代码执行

本地代码执行漏洞指攻击者通过向目标主机投递恶意载荷并诱导用户执行，触发本地操作系统或应用软件中的安全漏洞，从而在当前用户权限的安全上下文内执行攻击者构造的代码或系统命令。漏洞触发过程通常不依赖与攻击者之间的持续性远程网络连接。达成该危害效果的漏洞利用包括：钓鱼攻击、缓冲区溢出、DLL劫持等。

5.3.2 权限提升

权限提升漏洞指攻击者通过利用应用软件、操作系统或网络集中管控组件中的身份鉴别与访问控制缺陷，突破既定的安全隔离边界，非法获取超出其原有能力范围的访问与操作权限。在此上下文中，权限不仅指代传统的系统级账户控制权，也泛指对受保护资源及业务接口的直接访问能力，涵盖从无凭证的匿名越权访问，到同级数据边界跨越，再到跨层级的纵向控制权获取。达成该危害效果的漏洞利用包括：权限的纵向与横向突破、安全上下文的非法跨越、访问控制机制的彻底绕过等。

5.3.2.1 应用级权限提权

应用级权限提升漏洞指在Web应用、业务系统或API接口中，因身份校验与访问控制策略执行不严，导致攻击者能够非法突破应用层的逻辑隔离边界，实现包括在无凭证状态下直接访问受保护资源（未授权访问）、利用合法普通账户操作同级其他用户专属数据（水平越权），以及从低权限普通角色非法跃升至该系统管理员角色(垂直越权)在内的权限非法扩张，从而全面掌控应用系统的核心数据与业务流。达成该危害效果的漏洞利用包括：不安全的直接对象引用（IDOR）、越权API调用、会话伪造与劫持等。

5.3.2.2 系统级权限提权

系统级权限提升漏洞指在单台目标服务器的宿主操作系统中，因系统服务、驱动程序或底层核心组件存在安全缺陷，导致攻击者（通常已通过应用层漏洞等方式获得了受限的普通系统进程执行权）能够突破操作系统用户态的隔离边界，将自身权限跨越式提升至操作系统的最高控制权(如Windows的System权限或Linux的Root权限），致使单机环境下的访问控制机制彻底失效。达成该危害效果的漏洞利用包括：内核级提权漏洞利用、SUID/SUDO配置不当提权等。

5.3.2.3 集控设施级权限提升

集控设施级权限提升漏洞指在企业的网络基础设施或集中管控平台(如域控制器、云底座管理平台、核心路由交换设备）中存在深层次的权限控制缺陷，导致攻击者能够以受控的单机节点或普通的低级域账户为跳板，突破单点物理或逻辑安全边界，夺取跨设备、跨网段的全局网络最高控制权（如域管理员Domain Admin权限），具备全面掌控并瘫痪内网或云环境的毁灭性能力。达成该危害效果的漏洞利用包括：Active Directory黄金票据攻击、云控制台权限接管等。

5.3.3 防御突破

防御突破漏洞指攻击者利用目标系统部署的身份验证、访问控制、隔离边界、信任链等结构性安全机制缺陷，绕过或瓦解其纵深防御体系，实现攻击行为的隐匿、防御规则的绕过、安全容器的逃逸或网络边界的穿透等，集中作用在主机与网络两个层面。

5.3.3.1 隐匿

隐匿漏洞指攻击者通过内核级对象篡改、日志污染、无文件驻留或网络混淆等技术，破坏系统的安全监控与审计机制，能够在目标主机上长期隐匿恶意进程、文件、网络连接及活动痕迹，从而规避安全检测与事后取证，破坏系统可观测性。达成该危害效果的漏洞利用包括：内核级Hook、无文件持久化及加密C2通信等。

5.3.3.2 绕过

绕过漏洞指攻击者通过利用防护软件漏洞、篡改安全策略配置或滥用信任机制等方式，破坏防火墙、EDR、UAC等安全组件的正常功能，导致其丧失威胁检测、攻击阻断或事件响应能力，从而使目标系统暴露在未受保护的状态。达成该危害效果的漏洞利用包括：WAF绕过、杀毒软件绕过、终止安全软件进程、禁用日志功能等。

5.3.3.3 逃逸

逃逸漏洞指攻击者利用受控执行环境（沙盒、虚拟机或容器）中的隔离机制缺陷，突破预设的环境隔离保护边界，从而获得对宿主机系统或其底层资源的非授权访问与控制能力。达成该危害效果的漏洞利用包括：沙箱逃逸、容器逃逸、虚拟机逃逸等。

5.3.3.4 穿透

穿透漏洞指攻击者利用核心网络设备安全缺陷、协议漏洞、物理旁路攻击或隧道封装技术，突破防火墙、网闸、零信任网关等网络隔离设施，非法建立跨安全域的通信通道，破坏网络的安全域隔离，进而访问或渗透原本被逻辑隔离的对侧网络。达成该危害效果的漏洞利用包括：内网穿越等。

5.3.4 数据篡改

数据篡改漏洞指攻击者利用目标系统的安全缺陷，对其中存储或传输的静态或动态数据（如程序变量、数据库、内存、文件等）进行未授权的修改、替换、删除或注入等操作，破坏数据完整性。

5.3.4.1 应用程序数据篡改

应用程序数据篡改漏洞指攻击者利用漏洞后能够篡改应用程序运行时的动态数据（如数据变量、配置参数、程序状态、数据库记录等），从而影响程序正常执行流程或输出结果，破坏业务逻辑完整性。达成该危害效果的漏洞利用包括：SQL注入等。

5.3.4.2 内存数据篡改

内存篡改漏洞指攻击者利用进程或内核地址空间中内存管理机制的缺陷（如分配、访问或释放过程），能够对指定或任意范围的内存数据进行非授权篡改，破坏内存数据的完整性。达成该危害效果的漏洞利用包括：越界写等。

5.3.4.3 文件数据篡改

文件篡改漏洞指攻击者利用目标系统的文件访问与控制机制缺陷，能够对指定或任意目录下的静态文件（如可执行文件、配置文件、日志文件等）进行非授权的篡改、替换或删除，破坏文件数据的完整性。达成该危害效果的漏洞利用包括：路径穿越、符号链接攻击、竞态条件等。

5.3.5 数据泄露

数据泄露漏洞指攻击者利用目标系统的安全缺陷，非授权或越权获取其在存储、传输或处理过程中涉及的敏感信息（如用户隐私数据、业务数据、加密密钥、配置文件等），破坏数据机密性。

5.3.5.1 应用程序数据泄露

应用程序数据泄露漏洞指攻击者利用目标系统在数据处理或访问控制上的缺陷，能够非授权访问应用程序运行时的动态数据（如内存变量、实时配置、程序状态、数据库查询结果、API响应内容等），导致敏感信息（如账户凭证、用户隐私、业务逻辑等）的泄露，破坏应用数据的机密性。达成该危害效果的漏洞利用包括：SQL注入等。

5.3.5.2 内存数据泄露

内存数据泄露漏洞指攻击者利用进程或内核地址空间中内存管理机制的缺陷，能够非授权读取指定或任意范围的内存数据，导致敏感数据（如加密密钥、会话令牌或程序状态信息等）的泄露，破坏内存数据的机密性。达成该危害效果的漏洞利用包括：越界读等。

5.3.5.3 文件数据泄露

文件数据泄露漏洞指攻击者利用目标系统的文件访问控制机制缺陷，能够非授权读取指定或任意目录下的静态文件，导致敏感文件（如可执行文件、源代码、配置文件、日志文件等）的泄露，破坏文件数据的机密性。达成该危害效果的漏洞利用包括：路径穿越、符号链接、权限配置缺陷等。

5.3.5.4 传输数据泄露

传输数据泄露漏洞指攻击者利用未加密或弱保护通信通道、中间人位置或通信协议缺陷，截获在客户端与服务器、节点与节点之间传输的数据，导致敏感信息（如凭证、Cookie、业务报文、密钥更新流量等）的泄露，破坏传输数据的机密性。达成该危害效果的漏洞利用包括：流量镜像、无线窃听、侧信道攻击等。

5.3.6 拒绝服务

拒绝服务漏洞指攻击者通过利用目标系统的资源管理缺陷，消耗其关键资源或致使服务进程异常，从而导致系统服务完全中断或丧失正常响应合法请求的能力，破坏业务服务、系统或网络的可用性。

5.3.6.1 应用级拒绝服务

应用级拒绝服务漏洞指攻击者利用应用程序的漏洞或逻辑缺陷，通过构造特定恶意输入或执行非预期操作，导致应用程序崩溃、挂起或重新启动，从而使服务功能完全或部分失效，破坏应用程序层的可用性。

5.3.6.2 操作系统级拒绝服务

操作系统级拒绝服务漏洞指攻击者利用目标系统在资源分配与管理机制上的缺陷，通过恶意消耗或耗尽关键操作系统资源（如CPU计算周期、内存空间、磁盘I/O通道、网络带宽等），导致系统整体服务能力下降、长时间无响应或异常重启，破坏操作系统层的可用性。达成该危害效果的漏洞利用包括：内存耗尽、系统调用滥用、磁盘I/O饱和攻击等。

5.3.6.3 网络级拒绝服务

网络级拒绝服务漏洞指攻击者通过向目标网络持续发送大量恶意或伪造的数据流量，耗尽网络设备（如路由器、防火墙）的处理能力或关键链路（如带宽、会话连接数）的承载资源，导致其无法正常

接收、处理或转发合法用户的网络流量，破坏网络层的可用性。达成该危害效果的漏洞利用包括：泛洪Flooding、反射Reflection、放大Amplification等。

5.3.6.4 硬件级拒绝服务

硬件级拒绝服务漏洞指攻击者利用硬件设备的设计缺陷、物理安全漏洞或特定的电气、物理特性，通过注入恶意指令、触发异常工作状态或实施物理干扰，导致硬件组件发生永久性损坏、固件锁死或功能失效，破坏物理设备的可用性。达成该危害效果的漏洞利用包括：恶意固件注入与篡改攻击、未授权物理接口（如JTAG）滥用攻击、电源时序恶意操控攻击等。

5.3.6.5 服务质量降级

服务质量降级漏洞指攻击者通过针对性地消耗或干扰目标系统的部分关键资源（如CPU、内存、带宽、连接池等），导致服务性能显著下降（如响应延迟、吞吐量降低等），但尚未造成服务完全中断，破坏系统服务的可用性。达成该危害效果的漏洞利用包括：慢速攻击（如Slowloris）、带宽占用（如低强度DDoS）、协议滥用（如HTTP头部洪水）、侧信道干扰（如Cache侧信道）等。

6 网络安全漏洞分级

6.1 概述

网络安全漏洞分级是对漏洞危害程度进行量化定级的过程。本章内容涵盖漏洞分级指标与漏洞分级方法两大核心部分：漏洞分级指标由可利用性、影响程度和环境因素三个指标组构成，反映了漏洞的关键属性与赋值依据。漏洞分级方法规定了技术分级与综合分级两种分级方法的具体步骤，既可以对单一漏洞进行分级，也可以对组合漏洞进行分级。

6.2 漏洞分级指标

6.2.1 可利用性

6.2.1.1 攻击路径

攻击路径指触发漏洞的路径前提，反映了漏洞触发时与受影响产品或服务的最低接触程度。该指标的赋值选项包括：网络、邻接、本地和物理。通常因网络、邻接、本地和物理触发的漏洞，其可利用性由高到低依次降序，见表1。

表1　攻击路径赋值说明表

赋值	描述
网络	漏洞可以通过网络远程触发，攻击者可能在一个或多个网络跃点之外（如跨一个或多个路由器），如攻击者通过广域网发送特制的 TCP 数据包造成拒绝服务（DoS）。
邻接	漏洞需通过共享的物理网络或逻辑网络触发。攻击必须从同一共享物理（如蓝牙或 IEEE 802.11）或逻辑（如本地 IP 子网）网络发起，或从安全或其他受限的管理域（如 MPLS、安全 VPN 到管理网络区域）内发起。
本地	漏洞需要在本地环境中触发。攻击者通过物理接触（如键盘、控制台）或远程会话（如 SSH、RDP）等方式获得系统的本地操作权限后利用此漏洞；攻击者通过其他非直接交互渠道（如网络共享、邮件附件、U 盘）将恶意文件或指令投递至目标系统，并依赖合法用户交互（如点击、打开文件）后利用此漏洞。
物理	漏洞需通过物理接触/操作才能触发。如冷启动攻击，攻击者在物理访问目标系统后获得对磁盘加密密钥的访问权限。

6.2.1.2　攻击复杂度

攻击复杂度指漏洞成功触发过程的复杂性，反映了受影响产品或服务在现有安全增强技术因素影响下，成功触发漏洞所需采取的措施或克服的条件的复杂程度。该指标的赋值选项包括：低、高，通常攻击复杂度越低的漏洞可利用性越高，见表2。

表2　攻击复杂度赋值说明表

赋值	描述
低	攻击者不需要采取任何安全增强技术规避操作即可触发漏洞。
高	漏洞触发受限于安全增强技术因素，攻击者必须执行额外的攻击来绕过或破坏现有安全机制。

6.2.1.3　触发要求

触发要求指漏洞成功触发的先决条件，反映了受影响产品或服务在系统环境的版本、配置等因素影响下，成功触发漏洞的要求。该指标的赋值选项包括:无、存在。通常触发要求为“无”的漏洞危害程度高，见表3。

表3　触发要求赋值说明表

赋值	描述
无	漏洞触发对受影响产品或服务的配置参数、运行环境、版本等无特别要求，包括：默认的配置参数、普遍的运行环境。
存在	漏洞触发对受影响产品或服务的配置参数、运行环境等有特别要求，包括：不常用的参数配置、特殊的运行环境条件。

6.2.1.4　权限需求

权限需求指触发漏洞所需的权限,反映了漏洞成功触发需要的最低的权限。该指标的赋值选项包括：无、低和高，通常所需要的权限越少漏洞可利用性越高，见表4。

表4　权限需求赋值说明表

赋值	描述
无	漏洞触发无需特殊的权限，如公开权限、匿名访问权限。
低	漏洞触发需要较低的权限，如普通用户权限。
高	漏洞触发需要较高的权限，如管理员权限。

6.2.1.5　用户交互

用户交互指漏洞成功触发是否需要除攻击者之外的用户或系统的参与、配合，反映了是否可以仅根据攻击者的意愿利用漏洞，或是否必须由单独的用户（或用户启动的进程）以某种方式参与。该指标的赋值选项包括：无、被动、主动。通常不需要用户交互就能够触发的漏洞可利用性较高，见表5。

表5　交互条件赋值说明表

赋值	描述
无	漏洞成功触发不需要除攻击者之外的用户或系统的参与、配合。
被动	漏洞成功触发需要除攻击者之外的用户或系统的参与、配合。成功利用此漏洞需要用户与目标系统或攻击载荷进行有限的、非自愿的交互，并且不需要用户主动破坏目标系统内置的保护。如 XSS、CSRF 等漏洞需要用户的参与。
主动	漏洞成功触发需要除攻击者之外的用户或系统的参与、配合。成功利用此漏洞需要用户与目标系统或攻击载荷执行特定的、有意识的交互，或用户交互主动破坏目标系统内置的保护机制，从而导致利用该漏洞。如以特定方式将文件导入易受攻击的应用程序，在执行代码之前将文件放入特定目录，将特定字符串提交到 WEB 应用程序（如反射型 XSS），在执行操作（如打开/编辑文件、连接设备）之前关闭或接受提示或安全警告。

6.2.2　影响程度

6.2.2.1　保密性影响

保密性影响反映了漏洞攻击对受影响产品或服务（如系统、模块、软硬件等）造成直接或间接的保密性技术危害。其中，直接影响反映了漏洞攻击对受影响产品或服务造成的最直接且可预测的保密性影响，间接影响反映了漏洞攻击对与受影响产品或服务相关的后继影响组件的保密性影响。该指标的赋值选项包括：高、低和无，其中造成受影响系统的损失越高的漏洞危害程度越高，见表6和表7。

表6　直接影响-保密性赋值说明表

赋值	描述
高	保密性完全丢失，导致受影响系统的所有信息资源暴露给攻击者；或被暴露的受限信息能够造成受影响系统直接的严重信息丢失。如攻击者窃取管理员的口令或 WEB 服务器的私有加密密钥。
低	保密性部分丢失，攻击者可以获取一些受限信息，但无法控制获得信息的数量和种类。被暴露的信息不会引起受影响系统直接的、严重的信息丢失。
无	保密性无影响。漏洞对保密性不产生影响。

表7　间接影响-保密性赋值说明表

赋值	描述
高	保密性完全丢失，导致后继影响组件中的所有信息资源暴露给攻击者；或被暴露的受限信息能够造成后继影响组件直接的严重信息丢失。如攻击者窃取管理员的口令或 WEB 服务器的私有加密密钥。
低	保密性部分丢失，攻击者可以获取一些受限信息，但无法控制获得信息的数量和种类。被暴露的信息不会对后继影响组件造成直接的、严重的信息丢失。
无	保密性无影响。漏洞对后继影响组件的保密性不产生影响，或所有保密性影响都仅限于受影响系统自身。

6.2.2.2　完整性影响

完整性影响反映了漏洞攻击对受影响产品或服务（如系统、模块、软硬件等）造成直接或间接的完整性技术危害。其中，直接影响反映了漏洞攻击对受影响产品或服务造成的最直接且可预测的完整性影响，间接影响反映了漏洞攻击对与受影响产品或服务相关的后继影响组件的完整性影响。该指标的赋值选项包括：高、低和无，其中造成受影响系统的损失越高的漏洞危害程度越高，见表8和表9。

表8　直接影响-完整性影响赋值说明表

赋值	描述
高	完整性破坏严重，完整性完全丢失。攻击者能够修改受影响系统中的任何信息；或攻击者只能修改部分信息，但是能够对受影响系统造成直接的、严重的后果。
低	完整性破坏程度一般，完整性部分丢失。攻击者可以修改数据，但无法控制修改的后果，或修改量有限。数据修改不会对受影响系统产生直接的、严重的影响。
无	完整性无影响。漏洞对完整性不产生影响。

表9　间接影响-完整性影响赋值说明表

赋值	描述
高	完整性破坏严重，完整性完全丢失。攻击者能够修改后继影响组件中的任何信息；或攻击者只能修改部分信息，但是能够对后继影响组件造成直接的、严重的后果。
低	完整性破坏程度一般，完整性部分丢失。攻击者可以修改数据，但无法控制修改的后果，或修改量有限。数据修改不会对后继影响组件产生直接的、严重的影响。
无	完整性无影响。漏洞对后继影响组件的完整性不产生影响，或所有完整性影响都仅限于受影响系统自身。

6.2.2.3　可用性影响

可用性影响反映了漏洞攻击对受影响产品或服务（如系统、模块、软硬件等）造成直接或间接的可用性技术危害。其中，直接影响反映了漏洞攻击对受影响产品或服务造成的最直接且可预测的可用性影响，间接影响反映了漏洞攻击对与受影响产品或服务相关的后继影响组件的可用性影响。

可用性影响的赋值包括：高、低和无，其中造成受影响系统的损失越高的漏洞危害程度越高，见表10和表11。

表10　直接影响-可用性影响赋值说明表

赋值	描述
高	可用性遭受严重破坏，可用性完全丧失。攻击者可通过完全破坏受影响系统中的信息资源，使其可用性彻底丧失；或仅破坏部分信息资源的可用性，但能够对受影响系统产生直接且严重的后果。如攻击者无法中断现有连接，但可以阻止新连接;攻击者可以反复利用一个漏洞，在每次成功攻击的情况下，该漏洞仅泄漏少量内存，但是在重复利用后会导致服务变得完全不可用。
低	可用性遭受一定程度破坏，可用性部分丧失。攻击者能够降低受影响系统中信息资源的性能或导致其可用性中断。受影响系统的信息资源是部分可用，或部分时间完全可用，但总体上不会给受影响系统带来直接且严重的后果。
无	可用性无影响。漏洞对可用性不产生影响。

表11　间接影响-可用性影响赋值说明表

赋值	描述
高	可用性遭受严重破坏，可用性完全丧失。攻击者可通过完全破坏后继影响组件中的信息资源，使其可用性彻底丧失；或仅破坏部分信息资源的可用性，但能够对后继影响组件产生直接且严重的后果。如攻击者无法中断现有连接，但可以阻止新连接;攻击者可以反复利用一个漏洞，在每次成功攻击的情况下，该漏洞仅泄漏少量内存，但是在重复利用后会导致服务变得完全不可用。
低	可用性遭受一定程度破坏，可用性部分丧失。攻击者能够降低后继影响组件中信息资源的性能或导致其可用性中断。后继影响组件的信息资源是部分可用，或部分时间完全可用，但总体上不会给后继影响组件带来直接且严重的后果。
无	可用性无影响。漏洞对后继影响组件的可用性不产生影响，或所有可用性影响都仅限于受影响系统自身。

6.2.3　环境因素

6.2.3.1　利用成熟度

利用成熟度指利用漏洞实施攻击的可能性，需要根据威胁情报确定漏洞利用技术的当前状态、漏洞利用代码可用性或漏洞在野利用情况等。该指标的赋值选项包括：公开EXP、在野利用、概念验证和无。通常存在公开EXP情况的漏洞危害程度较高，见表12。

表12　利用成熟度赋值说明表

赋值	描述
公开 EXP	可通过公开途径获取到该漏洞的利用代码或利用工具。
在野利用	有确切的威胁情报说明该漏洞已有在野利用（如漏洞安全新闻事件、病毒利用漏洞事件、APT 组织利用漏洞事件等），即使未能成功攻破相关系统。
概念验证	基于目前的威胁情报未发现该漏洞的在野利用，但已经有公开的漏洞概念验证（POC）。此处的概念验证可以是漏洞的静态源代码分析过程、触发漏洞的简单示例等。
无	基于目前的威胁情报未发现该漏洞的在野利用和概念验证，没有公开资料可以准确确定漏洞产生的具体位置。
默认	默认值选择潜在危害最大赋值，即利用成熟度为“公开 EXP”。

6.2.3.2　潜在损失

业务潜在损失指漏洞被利用后对组织自身业务潜在的影响程度。该指标的赋值选项包括：严重、高、中和低。通常业务潜在损失高的漏洞危害程度较高，见表13。

表13　业务潜在损失赋值说明表

赋值	描述
严重	直接导致关键业务完全中断，或核心敏感数据（如核心技术、用户隐私等）泄露，造成不可挽回损失。
高	关键业务运行受显著影响（如效率大幅下降、频繁中断），或非核心但重要数据泄露，可能引发后续危害。
中	仅局部组件（如非关键模块、边缘系统）受影响，关键业务正常运行，仅泄露无关紧要的非敏感数据。
低	对业务流程无实质影响，仅存在极轻微异常（如显示瑕疵），无任何数据泄露危害。
默认	危害信息不全时，按潜在最大危害赋值，即默认“严重”。

社会潜在损失指漏洞被利用后潜在的社会影响程度，需要根据漏洞组件的用户体量、社会认可度、互联网暴露程度、应用行业领域及关联业务重要性等综合判定。该指标的赋值选项包括：严重、高、中和低。通常社会潜在损失高的漏洞危害程度较高，见表14。

表14　社会潜在损失赋值说明表

赋值	描述
严重	漏洞组件的用户群体广泛、社会认可度高、互联网暴露数量巨大，或在关键行业领域的核心生产系统中普遍使用；漏洞被利用后，会对国家安全、社会秩序和公共利益等造成严重损害。
高	漏洞组件的用户群体较广、社会认可度较好、互联网暴露数量较大，或在重要行业领域的主要生产系统中普遍使用；漏洞被利用后，会对社会秩序和公共利益等造成较大损害。
中	漏洞组件的用户群体一般、社会认可度一般、互联网暴露程度中等；漏洞被利用后，对社会秩序和公共利益等造成的损害有限，可能引发小范围公共利益受损。
低	漏洞组件的用户群体较少、社会认可度较低、互联网暴露程度低；漏洞被利用后，对社会秩序和公共利益等基本无损害，几乎不会产生明显的社会影响。
默认	默认值选择潜在危害最大赋值，即社会影响为“严重”。

6.2.3.3　响应程度

修复成本指基于现阶段漏洞修复方案（补丁或缓解措施），修复漏洞的难易程度及所需成本。该指标的赋值选项包括：高、中和低。通常修复成本高的漏洞危害程度较高，见表15。

表15　修复复杂度赋值说明表

赋值	描述
高	缺少有效、可行的修复方案，或修复方案难以执行，如无法获取相应的漏洞补丁、由于某种原因无法安装补丁等。
中	虽然有修复方案，但是需要付出一定的成本，或修复方案可能影响系统的使用，或修复方案非常复杂，适用性差，如虽然有临时修复措施，但是需要关闭某些网络服务等。
低	已有完善可落地的修复方案。

恢复难度指组件或系统被攻击后恢复正常运行的难易程度。该指标的赋值选项包括：自动恢复、简单恢复、复杂恢复和无法恢复。通常恢复难度高的漏洞危害程度较高，见表16。

表16　恢复难度赋值说明表

赋值	描述
自动恢复	组件或系统被攻击后可以自动恢复为正常运行状态。
简单恢复	组件或系统被攻击后需通过用户人为干预才能恢复为正常运行状态。
复杂恢复	组件或系统被攻击后只能通过开发商或专业技术人员恢复，恢复成本较高。
无法恢复	组件或系统被攻击后完全无法恢复。
默认	默认值选择潜在危害最大赋值，即恢复难度为“无法恢复”。

6.2.3.4　防护能力

防护能力指网络产品或服务在其实际生产环境部署的运行时环境中，所具备的、可有效抵御外部网络攻击的综合性防护策略与机制的水平，反映了攻击者通过网络途径成功利用该产品或服务中漏洞所需克服的防护难度。该指标的赋值选项包括：无保护的互联网访问、简单保护的互联网访问、复杂保护的互联网访问、逻辑隔离的非互联网访问和物理隔离。通常无保护的互联网访问情况的漏洞危害程度较高，见表17。

表17　防护能力赋值说明表

赋值	描述
无保护的互联网访问	无任何保护措施的可直接访问互联网的网络。
简单保护的互联网访问	部署网络防火墙并进行基本策略配置的可以访问互联网的网络。
复杂保护的互联网访问	具备下一代防火墙、入侵检测系统、终端防护等多层纵深防御措施的可访问互联网的网络。
逻辑隔离的非互联网访问	采用单向或双向网闸逻辑隔离的非互联网访问的网络。
物理隔离	采用物理方法与其他网络彻底隔离的网络。
默认	默认值选择潜在危害最大赋值，即防护能力为“无保护的互联网访问”。

6.3　漏洞分级方法

6.3.1　技术分级

网络安全漏洞技术分级是从技术原理角度界定漏洞对网络产品或系统的固有危害程度，共划分为超危、高危、中危、低危四个等级，主要适用于网络产品和服务的提供者对特定产品或系统漏洞的评估工作。该分级由可利用性与影响程度两个指标组综合决定：漏洞被利用可能性越高（可利用性评分越高）、影响程度越严重（影响程度评分越高），漏洞技术分级的级别越高（漏洞危害程度越大）。漏洞技术分级方法如下：

首先，对可利用性指标进行赋值，根据赋值结果，按照附录A计算得到漏洞的可利用性评分；

然后，对影响程度指标进行赋值，根据赋值结果，按照附录B计算得到漏洞的影响程度评分；

最后，根据可利用性和影响程度评分的结果，按照附录D计算得到网络安全漏洞技术分级。

6.3.2　综合分级

网络安全漏洞综合分级指漏洞在特定时空环境下，对网络产品或系统所承载业务的现实危害程度，共划分为超危、高危、中危、低危四个等级。该分级由可利用性、影响程度和环境因素三个指标组综合决定：漏洞被利用可能性越高（可利用性评分越高)、影响程度越严重（影响程度评分越高)，环境对漏洞影响越敏感（环境因素评分越高)，漏洞综合分级的级别越高（漏洞危害程度越大)。漏洞综合分级方法如下:

首先，依据漏洞技术分级方法，对可利用性和影响程度指标进行赋值。根据赋值结果，分别按照附录A和附录B计算得出可利用性评分与影响程度评分；进而依据附录D计算得到漏洞技术分级。

然后，对环境因素指标进行赋值。对于信息缺失或不明确的指标项，应采用该指标的默认值。根据赋值结果，按照附录C计算得到漏洞环境因素评分。

最后，结合漏洞技术分级和环境因素评分的结果，按照附录E计算得到网络安全漏洞综合分级。具体漏洞分级示例参见附录G。

附 录 A
（规范性）
可利用性评分表

可利用性评分见表A.1。

表A.1 可利用性评分表

序号	攻击路径	触发要求	权限需求	用户交互	攻击复杂度	可利用性评分
1	网络	无	无	无	低	9
2	邻接	无	无	无	低	
3	网络	无	无	被动	低	
4	网络	无	低	无	低	
5	网络	无	无	无	高	8
6	网络	存在	无	无	低	
7	邻接	无	无	被动	低	
8	邻接	无	低	无	低	
9	本地	无	无	无	低	
10	网络	无	低	被动	低	
11	邻接	无	无	无	高	7
12	邻接	存在	无	无	低	
13	网络	无	无	主动	低	
14	网络	无	无	被动	高	
15	网络	无	低	无	高	
16	网络	无	高	无	低	
17	网络	存在	无	被动	低	
18	网络	存在	低	无	低	
19	邻接	无	低	被动	低	
20	本地	无	无	被动	低	
21	本地	无	低	无	低	
22	网络	存在	无	无	高	6
23	邻接	无	无	主动	低	
24	邻接	无	无	被动	高	
25	邻接	无	低	无	高	
26	邻接	无	高	无	低	
27	邻接	存在	无	被动	低	
28	邻接	存在	低	无	低	
29	本地	无	无	无	高	
30	本地	存在	无	无	低	
31	物理	无	无	无	低	

表A.1（续）

序号	攻击路径	触发要求	权限需求	用户交互	攻击复杂度	可利用性评分
32	网络	无	低	被动	高	5
33	网络	无	低	主动	低	
34	网络	无	高	被动	低	
35	网络	存在	低	被动	低	
36	本地	无	低	被动	低	
37	邻接	存在	无	无	高	
38	网络	无	无	主动	高	
39	网络	无	高	无	高	
40	网络	存在	无	主动	低	
41	网络	存在	无	被动	高	
42	网络	存在	低	无	高	
43	网络	存在	高	无	低	
44	邻接	无	低	被动	高	
45	邻接	无	低	主动	低	
46	邻接	无	高	被动	低	
47	邻接	存在	低	被动	低	
48	本地	无	无	主动	低	
49	本地	无	无	被动	高	
50	本地	无	低	无	高	
51	本地	无	高	无	低	
52	本地	存在	无	被动	低	
53	本地	存在	低	无	低	
54	物理	无	无	被动	低	
55	物理	无	低	无	低	
56	邻接	无	无	主动	高	4
57	邻接	无	高	无	高	
58	邻接	存在	无	主动	低	
59	邻接	存在	无	被动	高	
60	邻接	存在	低	无	高	
61	邻接	存在	高	无	低	
62	本地	存在	无	无	高	
63	物理	无	无	无	高	
64	物理	存在	无	无	低	
65	网络	无	低	主动	高	
66	网络	无	高	被动	高	
67	网络	无	高	主动	低	
68	网络	存在	低	被动	高	
69	网络	存在	低	主动	低	
70	网络	存在	高	被动	低	

表A.1（续）

序号	攻击路径	触发要求	权限需求	用户交互	攻击复杂度	可利用性评分
71	本地	无	低	被动	高	
72	本地	无	低	主动	低	
73	本地	无	高	被动	低	4
74	本地	存在	低	被动	低	
75	物理	无	低	被动	低	
76	网络	存在	无	主动	高	
77	网络	存在	高	无	高	
78	邻接	无	低	主动	高	
79	邻接	无	高	被动	高	
80	邻接	无	高	主动	低	
81	邻接	存在	低	被动	高	
82	邻接	存在	低	主动	低	
83	邻接	存在	高	被动	低	
84	本地	无	无	主动	高	
85	本地	无	高	无	高	
86	本地	存在	无	主动	低	
87	本地	存在	无	被动	高	3
88	本地	存在	低	无	高	
89	本地	存在	高	无	低	
90	物理	无	无	主动	低	
91	物理	无	无	被动	高	
92	物理	无	低	无	高	
93	物理	无	高	无	低	
94	物理	存在	无	被动	低	
95	物理	存在	低	无	低	
96	邻接	存在	无	主动	高	
97	邻接	存在	高	无	高	
98	物理	存在	无	无	高	
99	网络	无	高	主动	高	
100	网络	存在	低	主动	高	
101	网络	存在	高	被动	高	
102	网络	存在	高	主动	低	
103	本地	无	低	主动	高	
104	本地	无	高	被动	高	2
105	本地	无	高	主动	低	
106	本地	存在	低	被动	高	
107	本地	存在	低	主动	低	
108	本地	存在	高	被动	低	

表A.1（续）

序号	攻击路径	触发要求	权限需求	用户交互	攻击复杂度	可利用性评分
109	物理	无	低	被动	高	
110	物理	无	低	主动	低	
111	物理	无	高	被动	低	
112	物理	存在	低	被动	低	
113	邻接	无	高	主动	高	
114	邻接	存在	低	主动	高	
115	邻接	存在	高	被动	高	
116	邻接	存在	高	主动	低	
117	本地	存在	无	主动	高	
118	本地	存在	高	无	高	
119	物理	无	无	主动	高	
120	物理	无	高	无	高	
121	物理	存在	无	主动	低	
122	物理	存在	无	被动	高	2
123	物理	存在	低	无	高	
124	物理	存在	高	无	低	
125	网络	存在	高	主动	高	
126	本地	无	高	主动	高	
127	本地	存在	低	主动	高	
128	本地	存在	高	被动	高	
129	本地	存在	高	主动	低	
130	物理	无	低	主动	高	
131	物理	无	高	被动	高	
132	物理	无	高	主动	低	
133	物理	存在	低	被动	高	
134	物理	存在	低	主动	低	
135	物理	存在	高	被动	低	
136	邻接	存在	高	主动	高	
137	物理	存在	无	主动	高	
138	物理	存在	高	无	高	
139	本地	存在	高	主动	高	
140	物理	无	高	主动	高	1
141	物理	存在	低	主动	高	
142	物理	存在	高	被动	高	
143	物理	存在	高	主动	低	
144	物理	存在	高	主动	高	
备注	按照“攻击路径”、“触发要求”、“权限需求”、“用户交互”、“攻击复杂度”的不同，可分为144种组合情况，按照每种组合的可利用程度的差异，从高到低可分为9个级别。					

附 录 B
（规范性）
影响程度评分表

影响程度评分见表B.1。

表B.1 影响程度评分表

序号	直接影响中的“高”（次数）	间接影响中的“高”（次数）	低或无（次数）	影响程度评分
1	3	3	0	4
2	3	2	1	4
3	3	1	2	4
4	3	0	3	4
5	2	3	1	3
6	2	2	2	3
7	2	1	3	3
8	2	0	4	3
9	1	3	2	2
10	1	2	3	2
11	1	1	4	2
12	1	0	5	2
13	0	3	3	1
14	0	2	4	1
15	0	1	5	1
16	0	0	6	1
备注	本文件按照保密性、完整性、可用性权重相同的原则，基于技术危害指标（“高”、“低”、“无”）的16种数量组合情况，建立影响程度与分值的映射关系。根据技术危害程度的差异，将影响程度划分为4个分值等级（1分~4分）。如：高出现3次，低出现3次，无出现0次，则技术危害的组合可能性：直接影响-保密性（高），直接影响-完整性（高），直接影响-可用性（高），间接影响-保密性（无），间接影响-完整性（无），间接影响-可用性（无）。			

附 录 C
（规范性）
环境因素评分表

环境因素评分见表C.1。

表C.1 环境因素评分表

序号	利用成熟度	潜在损失	响应程度	防护能力	环境因素评分
1	公开 EXP	高	高	无保护	9
2	在野利用	高	高	无保护	
3	公开 EXP	高	高	简单保护	8
4	公开 EXP	高	中	无保护	
5	公开 EXP	中	高	无保护	
6	在野利用	高	中	无保护	
7	在野利用	中	高	无保护	
8	概念验证	高	高	无保护	
9	公开 EXP	高	高	复杂保护	7
10	公开 EXP	高	高	逻辑隔离	
11	公开 EXP	高	中	简单保护	
12	公开 EXP	高	低	无保护	
13	公开 EXP	中	高	简单保护	
14	公开 EXP	中	中	无保护	
15	公开 EXP	低	高	无保护	
16	在野利用	高	高	简单保护	
17	在野利用	高	高	复杂保护	
18	在野利用	中	中	无保护	
19	概念验证	高	高	简单保护	
20	概念验证	高	中	无保护	
21	概念验证	中	高	无保护	
22	无	高	高	无保护	

表C.1（续）

序号	利用成熟度	潜在损失	响应程度	防护能力	环境因素评分
23	公开 EXP	高	高	物理隔离	6
24	公开 EXP	高	中	复杂保护	
25	公开 EXP	高	中	逻辑隔离	
26	公开 EXP	高	低	简单保护	
27	公开 EXP	中	高	复杂保护	
28	公开 EXP	中	高	逻辑隔离	
29	公开 EXP	中	中	简单保护	
30	公开 EXP	中	低	无保护	
31	公开 EXP	低	高	简单保护	
32	公开 EXP	低	中	无保护	
33	在野利用	高	高	逻辑隔离	
34	在野利用	高	高	物理隔离	
35	在野利用	高	中	简单保护	
36	在野利用	高	中	复杂保护	
37	在野利用	高	低	无保护	
38	在野利用	中	高	简单保护	
39	在野利用	中	高	复杂保护	
40	在野利用	低	高	无保护	
41	概念验证	高	高	复杂保护	
42	概念验证	高	中	简单保护	
43	概念验证	高	低	无保护	
44	概念验证	中	高	简单保护	
45	概念验证	中	中	无保护	
46	概念验证	低	高	无保护	
47	无	高	中	无保护	
48	无	中	高	无保护	

表C.1（续）

序号	利用成熟度	潜在损失	响应程度	防护能力	环境因素评分
49	公开 EXP	高	中	物理隔离	
50	公开 EXP	高	低	复杂保护	
51	公开 EXP	中	高	物理隔离	
52	公开 EXP	中	中	复杂保护	
53	公开 EXP	中	中	逻辑隔离	
54	公开 EXP	中	低	简单保护	
55	公开 EXP	低	高	复杂保护	
56	公开 EXP	低	中	简单保护	
57	公开 EXP	低	低	无保护	
58	在野利用	高	中	逻辑隔离	
59	在野利用	高	中	物理隔离	
60	在野利用	高	低	简单保护	
61	在野利用	中	高	逻辑隔离	
62	在野利用	中	高	物理隔离	
63	在野利用	中	中	简单保护	5
64	在野利用	中	中	复杂保护	
65	在野利用	中	低	无保护	
66	在野利用	低	高	简单保护	
67	在野利用	低	中	无保护	
68	概念验证	高	高	逻辑隔离	
69	概念验证	高	高	物理隔离	
70	概念验证	高	中	复杂保护	
71	概念验证	中	高	复杂保护	
72	概念验证	中	中	简单保护	
73	概念验证	中	低	无保护	
74	概念验证	低	中	无保护	
75	无	高	高	简单保护	
76	无	高	高	复杂保护	
77	无	中	中	无保护	

表C.1（续）

序号	利用成熟度	潜在损失	响应程度	防护能力	环境因素评分
78	公开 EXP	高	低	逻辑隔离	
79	公开 EXP	高	低	物理隔离	
80	公开 EXP	中	中	物理隔离	
81	公开 EXP	中	低	复杂保护	
82	公开 EXP	低	高	逻辑隔离	
83	公开 EXP	低	高	物理隔离	
84	公开 EXP	低	中	复杂保护	
85	在野利用	高	低	复杂保护	
86	在野利用	高	低	逻辑隔离	
87	在野利用	高	低	物理隔离	
88	在野利用	中	中	逻辑隔离	
89	在野利用	中	中	物理隔离	
90	在野利用	中	低	简单保护	
91	在野利用	低	高	复杂保护	
92	在野利用	低	高	逻辑隔离	
93	在野利用	低	高	物理隔离	
94	在野利用	低	中	简单保护	
95	在野利用	低	低	无保护	4
96	概念验证	高	中	逻辑隔离	
97	概念验证	高	中	物理隔离	
98	概念验证	高	低	简单保护	
99	概念验证	高	低	复杂保护	
100	概念验证	中	高	逻辑隔离	
101	概念验证	中	高	物理隔离	
102	概念验证	中	中	复杂保护	
103	概念验证	低	高	简单保护	
104	概念验证	低	高	复杂保护	
105	无	高	高	逻辑隔离	
106	无	高	高	物理隔离	
107	无	高	中	简单保护	
108	无	高	中	复杂保护	
109	无	高	低	无保护	
110	无	中	高	简单保护	
111	无	中	高	复杂保护	
112	无	低	高	无保护	

表C.1（续）

序号	利用成熟度	潜在损失	响应程度	防护能力	环境因素评分
113	公开 EXP	中	低	逻辑隔离	
114	公开 EXP	中	低	物理隔离	
115	公开 EXP	低	中	逻辑隔离	
116	公开 EXP	低	中	物理隔离	
117	公开 EXP	低	低	简单保护	
118	公开 EXP	低	低	复杂保护	
119	在野利用	中	低	复杂保护	
120	在野利用	中	低	逻辑隔离	
121	在野利用	中	低	物理隔离	
122	在野利用	低	中	复杂保护	
123	在野利用	低	中	逻辑隔离	
124	在野利用	低	中	物理隔离	
125	在野利用	低	低	简单保护	
126	概念验证	高	低	逻辑隔离	
127	概念验证	高	低	物理隔离	
128	概念验证	中	中	逻辑隔离	
129	概念验证	中	中	物理隔离	
130	概念验证	中	低	简单保护	3
131	概念验证	中	低	复杂保护	
132	概念验证	低	高	逻辑隔离	
133	概念验证	低	高	物理隔离	
134	概念验证	低	中	简单保护	
135	概念验证	低	中	复杂保护	
136	概念验证	低	低	无保护	
137	无	高	中	逻辑隔离	
138	无	高	中	物理隔离	
139	无	高	低	简单保护	
140	无	高	低	复杂保护	
141	无	中	高	逻辑隔离	
142	无	中	高	物理隔离	
143	无	中	中	简单保护	
144	无	中	中	复杂保护	
145	无	中	低	无保护	
146	无	低	高	简单保护	
147	无	低	高	复杂保护	

表C.1（续）

序号	利用成熟度	潜在损失	响应程度	防护能力	环境因素评分
148	无	低	中	无保护	3
149	公开 EXP	低	低	逻辑隔离	
150	公开 EXP	低	低	物理隔离	
151	在野利用	低	低	复杂保护	
152	在野利用	低	低	逻辑隔离	
153	概念验证	中	低	逻辑隔离	
154	概念验证	中	低	物理隔离	
155	概念验证	低	中	逻辑隔离	
156	概念验证	低	中	物理隔离	
157	概念验证	低	低	简单保护	
158	概念验证	低	低	复杂保护	
159	无	高	低	逻辑隔离	2
160	无	高	低	物理隔离	
161	无	中	中	逻辑隔离	
162	无	中	中	物理隔离	
163	无	中	低	简单保护	
164	无	中	低	复杂保护	
165	无	低	高	逻辑隔离	
166	无	低	高	物理隔离	
167	无	低	中	简单保护	
168	无	低	中	复杂保护	
169	无	低	低	无保护	

表C.1（续）

序号	利用成熟度	潜在损失	响应程度	防护能力	环境因素评分
170	在野利用	低	低	物理隔离	1
171	概念验证	低	低	逻辑隔离	
172	概念验证	低	低	物理隔离	
173	无	中	低	逻辑隔离	
174	无	中	低	物理隔离	
175	无	低	中	逻辑隔离	
176	无	低	中	物理隔离	
177	无	低	低	简单保护	
178	无	低	低	复杂保护	
179	无	低	低	逻辑隔离	
180	无	低	低	物理隔离	
备注	1）潜在损失：结合业务潜在损失和社会潜在损失，定义为： 高潜在损失： 业务损失=严重，社会损失=任何级别 社会损失=严重，业务损失=任何级别 业务损失=高，社会损失=高 中潜在损失： 业务损失=高，社会损失=中/低 社会损失=高，业务损失=中/低 业务损失=中，社会损失=中 低潜在损失： 业务损失=中，社会损失=低 业务损失=低，社会损失=中/低 2）响应程度：结合修复成本和恢复难度，定义为： 高响应程度： 恢复难度=无法恢复，修复成本=任何级别 恢复难度=复杂恢复，修复成本=高/中 恢复难度=简单/复杂恢复，修复成本=高 中响应程度： 恢复难度=简单恢复，修复成本=中 恢复难度=复杂恢复，修复成本=中/低 低响应程度： 恢复难度=自动恢复，修复成本=任何级别 恢复难度=简单恢复，修复成本=低 按“利用成熟度”、“潜在损失”、“响应程度”、“防护能力”，可分为180种组合情况，按照每种组合的技术危害程度的差异，从高到低可分为9个级别。				

附 录 D
（规范性）
漏洞技术分级表

漏洞技术分级见表D.1。

表D.1 漏洞技术分级表

影响程度评分 / 可利用性评分	4	3	2	1
9	超危	超危	高危	中危
8	超危	高危	高危	中危
7	高危	高危	中危	中危
6	高危	高危	中危	中危
5	中危	中危	中危	低危
4	中危	中危	低危	低危
3	中危	低危	低危	低危
2	低危	低危	低危	低危
1	低危	低危	低危	低危

附 录 E
（规范性）
漏洞综合分级表

漏洞综合分级见表E.1。

表E.1 漏洞综合分级表

环境因素评分 / 漏洞技术分级	环境因素评分 7-9	环境因素评分 4-6	环境因素评分 1-3
超危	超危	超危	高危
高危	超危	高危	中危
中危	高危	中危	低危
低危	中危	低危	低危

附 录 F
（资料性）
漏洞分类示例

F.1 示例一 Cisco Small Business RV320和RV325 输入验证错误漏洞（CNNVD-201901-877)分类示例

F.1.1 漏洞名称

Cisco Small Business RV320和RV325 输入验证错误漏洞（CNNVD-201901-877)

F.1.2 漏洞简介

Cisco Small Business RV320和RV325是美国思科（Cisco）公司的企业级路由器。固件版本在1.4.2.15至1.4.2.19之间的Cisco Small Business RV320和RV325设备存在命令注入漏洞，该漏洞是由于程序没有正确地验证用户提交的输入数据，拥有管理员权限的远程攻击者可通过发送特制的HTTP请求触发该漏洞，并以root权限在底层Linux shell上执行任意代码。

F.2 示例二 Cisco Small Business RV320和RV325 信息泄露漏洞（CNNVD-201901-876)分类示例

F.2.1 漏洞名称

Cisco Small Business RV320和RV325 信息泄露漏洞（CNNVD-201901-876)

F.2.2 漏洞简介

Cisco Small Business RV320和RV325是美国思科（Cisco）公司的企业级路由器。固件版本在1.4.2.15至1.4.2.19之间的Cisco Small Business RV320和RV325设备存在信息泄露漏洞，该漏洞是由于程序对URL访问控制不当导致未授权的用户可通过HTTP或HTTPS协议请求下载路由器配置信息，造成敏感信息泄露。

F.3 示例三 Cisco Small Business RV320和RV325 命令注入漏洞（CNNVD-201901-876和CNNVD-201901-877组合漏洞)分类示例

F.3.1 漏洞名称

Cisco Small Business RV320和RV325命令注入漏洞（CNNVD-201901-876和CNNVD-201901-877组合漏洞)

F.3.2 漏洞简介

Cisco Small Business RV320和RV325是美国思科（Cisco）公司的企业级路由器。固件版本在1.4.2.15至1.4.2.19之间的Cisco Small Business RV320和RV325设备存在命令注入漏洞，该漏洞是CNNVD-201901-876和CNNVD-201901-877组合而来，通过CNNVD-201901-876漏洞获取路由器配置信息，包括登录用户名和口令，随后结合CNNVD-201901-877漏洞完成在路由器上执行任意命令的目的。

F.4 基于缺陷的漏洞分类示例

根据三个漏洞的成因可将三个漏洞划分漏洞类型见表F.1。

表F.1 基于缺陷的漏洞分类示例

序号	漏洞名称	一级分类	二级分类	漏洞分类结果
1	Cisco Small Business RV320 和 RV325 输入验证错误漏洞（CNNVD-201901-877)	5.2.2 输入验证错误	5.2.2.4 命令注入	命令注入
2	Cisco Small Business RV320 和 RV325 信息泄露漏洞（CNNVD-201901-876)	5.2.7 信息泄露	-	信息泄露
3	Cisco Small Business RV320 和 RV325 命令注入漏洞（CNNVD-201901-876 和 CNNVD-201901-877 组合漏洞)	5.2.2 输入验证错误	5.2.2.4 命令注入	命令注入

F.5 基于影响的漏洞分类示例

根据三个漏洞的影响可将三个漏洞划分漏洞类型见表F.2。

表F.2 基于影响的漏洞分类示例

序号	漏洞名称	一级分类	二级分类	漏洞分类结果
1	Cisco Small Business RV320 和 RV325 输入验证错误漏洞（CNNVD-201901-877)	5.3.1 代码执行	5.3.1.3 服务端脚本代码执行	服务端脚本代码执行
2	Cisco Small Business RV320 和 RV325 信息泄露漏洞（CNNVD-201901-876)	5.3.2 权限提升	5.3.2.4 获取管理员权限	获取管理员权限
3	Cisco Small Business RV320 和 RV325 命令注入漏洞（CNNVD-201901-876 和 CNNVD-201901-877 组合漏洞)	5.3.1 代码执行	5.3.1.3 服务端脚本代码执行	服务端脚本代码执行

附 录 G
（资料性）
漏洞分级示例

G.1 示例一 OpenSSH资源管理错误漏洞（CNNVD-202502-3772)分级示例

G.1.1 漏洞名称

OpenSSH资源管理错误漏洞（CNNVD-202502-3772)

G.1.2 漏洞简介

OpenSSH是基于Secure Shell（SSH）协议的开源工具集。它可实现远程登录、文件传输等功能，通过加密技术防范数据泄露，是服务器管理等场景的常用工具。OpenSSH在处理特定的输入时未能有效限制资源的使用。攻击者可以发送特制的请求，恶意占用系统的内存和CPU资源，致使系统资源耗尽，造成拒绝服务问题。

G.1.3 漏洞分级示例

见表G.1。

表G.1 CNNVD-202502-3772 漏洞分级示例

指标类	指标子类		赋值描述	赋值结果	评分
可利用性	攻击路径		通过网络远程访问	网络	9
	攻击复杂度		不需要采取安全增强技术规避操作即可触发漏洞	高	
	触发要求		无需特定环境，普通环境即可触发	无	
	权限需求		无需任何特权信息或身份验证	无	
	用户交互		漏洞触发无需用户或系统的参与或配合	无	
影响程度	直接影响	保密性	漏洞对受影响系统的保密性不产生影响	无	1
		完整性	漏洞对受影响系统的完整性不产生影响	无	
		可用性	系统资源被占用，导致服务中断	低	
	间接影响	保密性	漏洞对后继影响组件的保密性不产生影响	无	
		完整性	漏洞对后继影响组件的完整性不产生影响	无	
		可用性	漏洞对后继影响组件的可用性不产生影响	无	

表G.1 （续）

环境因素	利用成熟度		互联网可以获取到该漏洞的利用代码或利用工具	公开EXP	5
	潜在损失	业务潜在损失	无任何数据泄露危害	低	
		社会潜在损失	漏洞被利用不会产生明显的社会影响	低	
	响应程度	修复成本	已有相应漏洞的补丁	低	
		恢复难度	组件或系统被攻击后可以自动恢复正常运行状态	自动恢复	
	防护能力		默认选择潜在危害最大赋值，即“无保护的互联网访问”	无保护的互联网访问	

G.1.4 漏洞分级

通过表G.1，CNNVD-202502-3772漏洞的可利用性为9级、影响程度为1级，因此技术分级为中危；同时，该漏洞的环境因素为5级，结合技术分级为中危，可知该漏洞的综合分级为中危。

G.2 示例二 Cisco Small Business RV320和RV325 输入验证错误漏洞（CNNVD-201901-877)分级示例

G.2.1 漏洞名称

Cisco Small Business RV320和RV325输入验证错误漏洞（CNNVD-201901-877）

G.2.2 漏洞简介

Cisco Small Business RV320和RV325是美国思科（Cisco）公司的企业级路由器。固件版本在1.4.2.15至1.4.2.19之间的Cisco Small Business RV320和RV325设备存在命令注入漏洞，该漏洞是由于程序没有正确地验证用户提交的输入数据，拥有管理员权限的远程攻击者可通过发送特制的HTTP请求触发该漏洞，并以root权限在底层Linux shell上执行任意代码。

G.2.3 漏洞分级示例

网络产品与服务提供商、网络运营者、漏洞收录平台及应急响应组织等不同主体可结合自身业务场景和安全需求，选取相应的评价指标对漏洞进行分级评估。漏洞分级结果的可能示例见表G.2.1-G.2.3。

表 G.2.1 CNNVD-201901-877 漏洞分级示例-网络产品和服务提供者

指标类	指标子类	赋值描述	赋值结果	评分
可利用性	攻击路径	通过网络远程访问	网络	7
	攻击复杂度	不需要采取安全增强技术规避操作即可触发漏洞	低	
	触发要求	无需特定环境，普通环境即可触发	无	
	权限需求	洞触发需要较高的权限，需要管理员权限	高	

表 G.2.1（续）

	用户交互		漏洞触发无需用户或系统的参与或配合	无	
影响程度	直接影响	保密性	受影响系统的所有信息资源暴露给攻击者，保密性完全丢失	高	4
		完整性	信息完整性破坏严重，完整性完全丢失	高	
		可用性	信息可用性破坏严重，可用性完全丧失	高	
	间接影响	保密性	漏洞对后继影响组件的保密性不产生影响	无	
		完整性	漏洞对后继影响组件的完整性不产生影响	无	
		可用性	漏洞对后继影响组件的可用性不产生影响	无	
环境因素	利用成熟度		互联网可以获取到该漏洞的利用代码或利用工具	公开EXP	5
	潜在损失	业务潜在损失	仅局部组件受影响，不会泄露敏感数据	中	
		社会潜在损失	漏洞被利用几乎不会产生明显的社会影响	低	
	响应程度	修复成本	已有相应漏洞的补丁	低	
		恢复难度	组件或系统被攻击后只能通过用户手动恢复为正常运行状态	简单恢复	
	防护能力		默认选择潜在危害最大赋值，即“无保护的互联网访问”	无保护的互联网访问	

表 G.2.2 CNNVD-201901-877 漏洞分级示例-网络运营者

指标类	指标子类	赋值描述	赋值结果	评分
可利用性	攻击路径	通过网络远程访问	网络	7
	攻击复杂度	不需要采取安全增强技术规避操作即可触发漏洞	低	
	触发要求	无需特定环境，普通环境即可触发	无	
	权限需求	洞触发需要较高的权限，需要管理员权限	高	
	用户交互	漏洞触发无需用户或系统的参与或配合	无	

表 G.2.2（续）

影响程度	直接影响	保密性	受影响系统的所有信息资源暴露给攻击者，保密性完全丢失	高	4
		完整性	信息完整性破坏严重，完整性完全丢失	高	
		可用性	信息可用性破坏严重，可用性完全丧失	高	
	间接影响	保密性	漏洞对后继影响组件的保密性不产生影响	无	
		完整性	漏洞对后继影响组件的完整性不产生影响	无	
		可用性	漏洞对后继影响组件的可用性不产生影响	无	
环境因素	利用成熟度		互联网可以获取到该漏洞的利用代码或利用工具	公开EXP	5
	潜在损失	业务潜在损失	直接导致关键业务完全中断	严重	
		社会潜在损失	信息不全，采用默认赋值	严重	
	响应程度	修复成本	已有相应漏洞的补丁	低	
		恢复难度	组件或系统被攻击后只能通过用户手动恢复为正常运行状态	简单恢复	
	防护能力		具备较为完善防护措施的可访问互联网的网络	复杂保护的互联网访问	

表 G.2.3 CNNVD-201901-877 漏洞分级示例-漏洞收录组织/漏洞应急组织

指标类	指标子类		赋值描述	赋值结果	评分
可利用性	攻击路径		通过网络远程访问	网络	7
	攻击复杂度		不需要采取安全增强技术规避操作即可触发漏洞	低	
	触发要求		无需特定环境，普通环境即可触发	无	
	权限需求		洞触发需要较高的权限，需要管理员权限	高	
	用户交互		漏洞触发无需用户或系统的参与或配合	无	
影响程度	直接影响	保密性	受影响系统的所有信息资源暴露给攻击者，保密性完全丢失	高	4

表 G.2.3（续）

		完整性	信息完整性破坏严重，完整性完全丢失	高	
		可用性	信息可用性破坏严重，可用性完全丧失	高	
	间接影响	保密性	漏洞对后继影响组件的保密性不产生影响	无	
		完整性	漏洞对后继影响组件的完整性不产生影响	无	
		可用性	漏洞对后继影响组件的可用性不产生影响	无	
环境因素	利用成熟度		互联网可以获取到该漏洞的利用代码或利用工具	公开EXP	7
	潜在损失	业务潜在损失	信息不全，采用默认赋值	严重	
		社会潜在损失	漏洞被利用产生较大的社会影响	高	
	响应程度	修复成本	已有相应漏洞的补丁	低	
		恢复难度	组件或系统被攻击后只能通过用户手动恢复为正常运行状态	简单恢复	
	防护能力		默认选择潜在危害最大赋值，即“无保护的互联网访问”	无保护的互联网访问	

G.2.4 漏洞分级

通过表G.2.1-G.2.3，CNNVD-201901-877漏洞的可利用性为7级、影响程度为4级，因此技术分级为高危；从网络产品和服务的提供者、网络运营者、漏洞收录组织、漏洞应急组织等不同用户角度，该漏洞的环境因素可能为5级、5级、7级，结合技术分级为高危，可知该漏洞的综合分级分别为高危、高危和超危。

G.3 示例三 Cisco Small Business RV320和RV325访问控制错误漏洞（CNNVD-201901-876）分级示例

G.3.1 漏洞名称

Cisco Small Business RV320和RV325访问控制错误漏洞（CNNVD-201901-876）

G.3.2 漏洞简介

Cisco Small Business RV320和RV325是美国思科（Cisco）公司的企业级路由器。固件版本在1.4.2.15至1.4.2.19之间的Cisco Small Business RV320和RV325设备存在信息泄露漏洞，该漏洞是由于程序对URL访问控制不当导致未授权的用户可通过HTTP或HTTPS协议请求下载路由器配置信息，造成敏感信息泄露。

G.3.3 漏洞分级示例

以下为漏洞从网络产品和服务的提供者、网络运营者、漏洞收录组织、漏洞应急组织等不同用户角度进行漏洞分级判定的可能结果，见表G.3.1-G.3.3。

表 G.3.1 CNNVD-201901-876 漏洞分级示例-网络产品和服务提供者

指标类	指标子类		赋值描述	赋值结果	评分
可利用性	攻击路径		通过网络远程访问	网络	9
	攻击复杂度		不需要采取安全增强技术规避操作即可触发漏洞	低	
	触发要求		无需特定环境，普通环境即可触发	无	
	权限需求		无需任何特权信息或身份验证	无	
	用户交互		漏洞触发无需用户或系统的参与或配合	无	
影响程度	直接影响	保密性	泄露信息能够造成受影响系统直接的严重信息丢失	高	2
		完整性	漏洞对受影响系统的完整性不产生影响	无	
		可用性	漏洞对受影响系统的可用性不产生影响	无	
	间接影响	保密性	漏洞对后继影响组件的保密性不产生影响	无	
		完整性	漏洞对后继影响组件的完整性不产生影响	无	
		可用性	漏洞对后继影响组件的可用性不产生影响	无	
环境因素	利用成熟度		互联网可以获取到该漏洞的利用代码或利用工具	公开EXP	6
	潜在损失	业务潜在损失	非核心但重要数据泄露，可能引发后续危害	高	
		社会潜在损失	漏洞被利用不会产生明显的社会影响	低	
	响应程度	修复成本	已有相应漏洞的补丁	低	
		恢复难度	漏洞不影响系统正常运行	自动恢复	
	防护能力		默认选择潜在危害最大赋值，即“无保护的互联网访问”	无保护的互联网访问	

表 G.3.2 CNNVD-201901-876 漏洞分级示例-网络运营者

指标类	指标子类		赋值描述	赋值结果	评分
可利用性	攻击路径		通过网络远程访问	网络	9
	攻击复杂度		不需要采取安全增强技术规避操作即可触发漏洞	低	
	触发要求		无需特定环境，普通环境即可触发	无	
	权限需求		无需任何特权信息或身份验证	无	
	用户交互		漏洞触发无需用户或系统的参与或配合	无	
影响程度	直接影响	保密性	泄露信息能够造成受影响系统直接的严重信息丢失	高	2
		完整性	漏洞对受影响系统的完整性不产生影响	无	
		可用性	漏洞对受影响系统的可用性不产生影响	无	
	间接影响	保密性	漏洞对后继影响组件的保密性不产生影响	无	
		完整性	漏洞对后继影响组件的完整性不产生影响	无	
		可用性	漏洞对后继影响组件的可用性不产生影响	无	
环境因素	利用成熟度		互联网可以获取到该漏洞的利用代码或利用工具	公开EXP	5
	潜在损失	业务潜在损失	非核心但重要数据泄露，可能引发后续危害	高	
		社会潜在损失	信息不全，采用默认赋值	严重	
	响应程度	修复成本	已有相应漏洞的补丁	低	
		恢复难度	漏洞不影响系统正常运行	自动恢复	
	防护能力		具备较为完善防护措施的可访问互联网的网络	复杂保护的互联网访问	

表 G.3.3 CNNVD-201901-876 漏洞分级示例-漏洞收录组织/漏洞应急组织

指标类	指标子类	赋值描述	赋值结果	评分
可利用性	攻击路径	通过网络远程访问	网络	9
	攻击复杂度	不需要采取安全增强技术规避操作即可触发漏洞	低	
	触发要求	无需特定环境，普通环境即可触发	无	
	权限需求	无需任何特权信息或身份验证	无	

表 G.3.3（续）

	用户交互		漏洞触发无需用户或系统的参与或配合	无	
影响程度	直接影响	保密性	泄露信息能够造成受影响系统直接的严重信息丢失	高	2
		完整性	漏洞对受影响系统的完整性不产生影响	无	
		可用性	漏洞对受影响系统的可用性不产生影响	无	
	间接影响	保密性	漏洞对后继影响组件的保密性不产生影响	无	
		完整性	漏洞对后继影响组件的完整性不产生影响	无	
		可用性	漏洞对后继影响组件的可用性不产生影响	无	
环境因素	利用成熟度		互联网可以获取到该漏洞的利用代码或利用工具	公开EXP	6
	潜在损失	业务潜在损失	非核心但重要数据泄露，可能引发后续危害	高	
		社会潜在损失	漏洞被利用对社会秩序和公共利益等造成的损害有限，可能引发小范围公共利益受损	中	
	响应程度	修复成本	已有相应漏洞的补丁	低	
		恢复难度	漏洞不影响系统正常运行	自动恢复	
	防护能力		默认选择潜在危害最大赋值，即“无保护的互联网访问”	无保护的互联网访问	

G.3.4 漏洞分级

通过表G.3.1-G.3.3，CNNVD-201901-876漏洞的可利用性为9级、影响程度为2级，因此技术分级为高危；从网络产品和服务的提供者、网络运营者、漏洞收录组织、漏洞应急组织等不同用户角度，该漏洞的环境因素可能为6级、5级、6级，结合技术分级为高危，可知该漏洞的综合分级为高危。

G.4 示例四 Cisco Small Business RV320和RV325命令注入漏洞（CNNVD-201901-876和CNNVD-201901-877组合漏洞）分级示例

G.4.1 漏洞名称

Cisco Small Business RV320和RV325 命令注入漏洞（CNNVD-201901-876和CNNVD-201901-877组合漏洞）

G.4.2 漏洞简介

Cisco Small Business RV320和RV325是美国思科（Cisco）公司的企业级路由器。固件版本在1.4.2.15至1.4.2.19之间的Cisco Small Business RV320和RV325设备存在命令注入漏洞，该漏洞是

CNNVD-201901-876和CNNVD-201901-877组合而来，通过CNNVD-201901-876漏洞获取路由器配置信息，包括登录用户名和口令，随后结合CNNVD-201901-877漏洞完成在路由器上执行任意命令的目的。

G.4.3 漏洞分级示例

以下为漏洞从网络产品和服务的提供者、网络运营者、漏洞收录组织、漏洞应急组织等不同用户角度进行漏洞分级判定的可能结果，见表G.4.1-G.4.3。

表 G.4.1 Cisco 组合漏洞分级-网络产品和服务提供者

指标类	指标子类		赋值描述	赋值结果	评分
可利用性	攻击路径		通过网络远程访问	网络	9
	攻击复杂度		不需要采取安全增强技术规避操作即可触发漏洞	低	
	触发要求		无需特定环境，普通环境即可触发	无	
	权限需求		无需任何特权信息或身份验证	无	
	用户交互		漏洞触发无需用户或系统的参与或配合	无	
影响程度	直接影响	保密性	受影响系统的所有信息资源暴露给攻击者，保密性完全丢失	高	4
		完整性	信息完整性破坏严重，完整性完全丢失	高	
		可用性	信息可用性破坏严重，可用性完全丧失	高	
	间接影响	保密性	漏洞对后继影响组件的保密性不产生影响	无	
		完整性	漏洞对后继影响组件的完整性不产生影响	无	
		可用性	漏洞对后继影响组件的可用性不产生影响	无	
环境因素	利用成熟度		互联网可以获取到该漏洞的利用代码或利用工具	公开EXP	6
	潜在损失	业务潜在损失	关键业务运行受显著影响，非核心但重要数据泄露，可能引发后续危害	高	
		社会潜在损失	漏洞被利用几乎不会产生明显的社会影响	低	
	响应程度	修复成本	已有相应漏洞的补丁	低	
		恢复难度	组件或系统被攻击后只能通过用户手动恢复为正常运行状态	简单恢复	
	防护能力		默认选择潜在危害最大赋值，即“无保护的互联网访问”	无保护的互联网访问	

表 G.4.2 Cisco 组合漏洞分级-网络运营者

指标类	指标子类		赋值描述	赋值结果	评分
可利用性	攻击路径		通过网络远程访问	网络	9
	攻击复杂度		不需要采取安全增强技术规避操作即可触发漏洞	低	
	触发要求		无需特定环境，普通环境即可触发	无	
	权限需求		无需任何特权信息或身份验证	无	
	用户交互		漏洞触发无需用户或系统的参与或配合	无	
影响程度	直接影响	保密性	受影响系统的所有信息资源暴露给攻击者，保密性完全丢失	高	4
		完整性	信息完整性破坏严重，完整性完全丢失	高	
		可用性	信息可用性破坏严重，可用性完全丧失	高	
	间接影响	保密性	漏洞对后继影响组件的保密性不产生影响	无	
		完整性	漏洞对后继影响组件的完整性不产生影响	无	
		可用性	漏洞对后继影响组件的可用性不产生影响	无	
环境因素	利用成熟度		互联网可以获取到该漏洞的利用代码或利用工具	公开EXP	5
	潜在损失	业务潜在损失	直接导致关键业务完全中断	严重	
		社会潜在损失	信息不全，采用默认赋值	严重	
	响应程度	修复成本	已有相应漏洞的补丁	低	
		恢复难度	组件或系统被攻击后只能通过用户手动恢复为正常运行状态	简单恢复	
	防护能力		具备较为完善防护措施的可访问互联网的网络	复杂保护的互联网访问	

表 G.4.3 Cisco 组合漏洞分级-漏洞收录组织/漏洞应急组织

指标类	指标子类	赋值描述	赋值结果	评分
可利用性	攻击路径	通过网络远程访问	网络	9
	攻击复杂度	不需要采取安全增强技术规避操作即可触发漏洞	低	
	触发要求	无需特定环境，普通环境即可触发	无	

表 G.4.3（续）

	权限需求		无需任何特权信息或身份验证	无	
	用户交互		漏洞触发无需用户或系统的参与或配合	无	
影响程度	直接影响	保密性	受影响系统的所有信息资源暴露给攻击者，保密性完全丢失	高	4
		完整性	信息完整性破坏严重，完整性完全丢失	高	
		可用性	信息可用性破坏严重，可用性完全丧失	高	
	间接影响	保密性	漏洞对后继影响组件的保密性不产生影响	无	
		完整性	漏洞对后继影响组件的完整性不产生影响	无	
		可用性	漏洞对后继影响组件的可用性不产生影响	无	
环境因素	利用成熟度		互联网可以获取到该漏洞的利用代码或利用工具	公开EXP	7
	潜在损失	业务潜在损失	信息不全，采用默认赋值	严重	
		社会潜在损失	漏洞被利用产生较大的社会影响	高	
	响应程度	修复成本	已有相应漏洞的补丁	低	
		恢复难度	组件或系统被攻击后只能通过用户手动恢复为正常运行状态	简单恢复	
	防护能力		默认选择潜在危害最大赋值，即“无保护的互联网访问”	无保护的互联网访问	

G.4.4 漏洞分级

通过表G.4.1-G.4.3，CNNVD-201901-877、CNNVD-201901-876组合漏洞的可利用性为9级、影响程度为4级，因此技术分级为高危；从网络产品和服务的提供者、网络运营者、漏洞收录组织、漏洞应急组织等不同用户角度，该漏洞的环境因素可能为6级、5级、7级，结合技术分级为高危，可知该漏洞的综合分级分别为高危、高危和超危。

附 录 H
（资料性）
漏洞分类兼容性说明

H.1 兼容性说明

本文件提出的基于缺陷的漏洞分类共46项，涵盖并完全兼容GB/T 30279-2020的24个分类，对于未采纳的6个分类，详细说明见附录H.1。本文件漏洞分类与GB/T 30279-2020完全兼容，在实践应用中不会与存量漏洞数据的分类结果产生冲突或矛盾。

表 H.1 与 GB/T 30279-2020 兼容性说明

GB/T 30279-2020章节号	漏洞类型	未采纳说明	兼容性说明
5.2	代码问题	此类型在GB/T 30279-2020中为一级分类，涵盖范围过于宽泛，实际应用中绝大多数漏洞均可归类至其子类（如输入验证、处理逻辑错误等）。为提升分类的精确性和实用性，本文件以其子类作为独立分类节点，不再保留此父级分类。	代码问题类型的漏洞在本文件中可根据具体成因归类到资源管理错误、缓冲区错误、输入验证错误、格式化字符串错误、跨站脚本、命令注入、代码注入、SQL注入、路径遍历、后置链接、跨站请求伪造、任意文件上传、提示词注入、处理逻辑错误、竞争条件问题、数字错误、异常处理不当、时序逻辑问题、加密问题、授权问题、信任管理问题、权限许可和访问控制问题、会话机制问题等。
5.2.3.3	注入	此类型在GB/T 30279-2020中作为多种注入类漏洞（如SQL注入、命令注入等）的父节点，实际应用中具体漏洞均直接归类至相应子类，导致该中间节点长期闲置。为提高分类效率，本文件不再保留此聚合节点，而是直接采用其子类作为细分类型。	注入类型的漏洞在本文件中可根据具体成因归类到格式化字符串错误、跨站脚本、命令注入、代码注入、SQL注入和输入验证错误等。

表 H.1（续）

5.2.9	数据转换问题	此类型在GB/T 30279-2020中指因数据编码、格式、类型等转换不一致引发的安全问题，其实际成因可分别归属于输入验证错误、输出处理不当或业务逻辑缺陷等更具体的类别。本文件从成因角度对其进行了分解归类，不再保留这一模糊分类。	数据转换问题类型的漏洞在本文件中可根据具体成因归类到输出验证错误、输入验证错误和处理逻辑错误类型等。
5.2.10	未声明功能	此类型在实际应用中极为罕见，且通常可归因于权限许可与访问控制问题，本文件不再对其进行单独列类。	未声明功能类型的漏洞在本文件中可根据具体成因归类到权限许可与访问控制问题。
5.4	环境问题	此类型在GB/T 30279-2020中主要用于描述外部环境因素引发的系统异常，实践中其子类信息泄露、侧信道信息泄露等已成为该类问题的主要体现。本文件直接采用上述子类作为分类节点，不再保留冗余的父级分类。	环境问题类型的漏洞在本文件中可根据具体成因归类到信息泄露、侧信道信息泄露、配置错误和资源管理错误类型等。
5.4.3	故障注入	此类型在GB/T 30279-2020中表示运行环境改变触发的漏洞在实际应用中较为少见。	故障注入类型的漏洞在本文件中可根据具体成因归类到信息泄露、侧信道信息泄露、配置错误和资源管理错误类型等。

H.2 新增类型说明

本文件中基于缺陷的漏洞分类与GB/T 30279—2020相比新增了22个漏洞类型，其中5个漏洞类型参考了国际标准，17个漏洞类型源于行业内实践。具体内容见表H.2。

表 H.2 新增漏洞类型说明

章节号	漏洞类型	描述	说明
5.2.2.9	服务端请求伪造	服务端请求伪造漏洞指在WEB应用中，因未充分验证用户输入的访问地址参数，导致受欺骗的服务端发送非预期的请求。	此漏洞类型参考国际标准CWE-434，在WEB应用系统中广泛存在，且实际危害较高。

表 H.2（续）

5.2.2.10	任意文件上传	任意文件上传漏洞指因未对上传的文件类型、内容和存储路径等进行严格校验，导致上传非限定文件引发的安全问题。	此漏洞类型参考国际标准CWE-434，在WEB应用系统中广泛存在，且实际危害较高。
5.2.2.11	反序列化注入	反序列化注入漏洞指在通过外部输入的序列化数据重建为对象的过程中，因未正确过滤其中的特殊元素，导致执行恶意代码逻辑，修改了网络产品和服务的预期执行控制流。	此漏洞类型的增加是源于业内安全实践，互联网应用程序在编码构建过程中，因数据持久化、网络通信和进程间通信的需要，将对象序列化存储和反序列化重建操作普遍存在。此类漏洞的重要性日益凸显。
5.2.3.3	异常处理不当	异常处理不当漏洞指在系统或程序的逻辑处理过程中，当遇到未预料的异常条件（如空指针解引用、资源异常等）时，由于缺乏充分的检查与处理机制，导致软件发生崩溃、退出或进入非预期状态。	此漏洞类型综合参考了国际标准CWE-248、CWE-703等关于异常处理不当引发问题的相关类型，在各类软件中普遍存在。
5.2.3.4	时序逻辑问题	时序逻辑问题漏洞指在软硬件系统运行过程中，由于时序逻辑处理不当导致的安全问题。	此漏洞类型参考工业控制、硬件及芯片领域的安全实践，随着物联网和关键信息基础设施安全要求的提升，此类漏洞的重要性日益凸显。
5.2.5.3	会话机制问题	会话机制问题漏洞指在身份认证过程中使用的会话机制存在缺陷，使会话凭证泄露或可预测，导致认证身份被劫持等安全问题。	此漏洞类型综合参考了国际标准CWE-287、CWE-295、CWE-384、CWE-613、CWE-255、CWE-522等关于会话机制处理处理不当引发问题的相关类型，在移动端认证领域使用广泛。
5.2.8	输出处理不当	输出处理不当洞指网络产品或服务对输出数据未进行有效的处理导致的安全问题。	此漏洞类型综合参考了国际标准CWE-80、CWE-81、CWE-82、CWE-83、CWE-84、CWE-87等关于输出处理不当引发问题的相关类型，在WEB和移动端应用方面使用广泛。

表 H.2（续）

5.2.9 5.2.9.1 5.2.9.2 5.2.9.3	供应链问题 软件供应链问题 硬件供应链问题 服务供应链问题	此类漏洞指软硬件系统服务及相关数据的全生命周期中，因开源库、商业软件、硬件设备等第三方组件存在固有缺陷或供应链各环节安全管控缺失导致的安全问题。	此漏洞类型参考了安全领域内的实践和学术领域研究。业内实践参考了《OWASP 2025 TOP 10: The Ten Most Critical Web Application Security Risks》。学术研究包括：IEEE安全与隐私研讨会的论文《SoK: Taxonomy of Attacks on Open-Source Software Supply Chains》、《On the prevalence of software supply chain attacks: Empirical study and investigative framework》、《Advanced Persistent Threats Based on Supply Chain Vulnerabilities》。
5.2.10 5.2.10.1 5.2.10.2 5.2.10.3 5.2.10.4 5.2.10.5 5.2.10.6 5.2.10.7 5.2.10.8 5.2.10.9 5.2.10.10	人工智能模型训练推理问题 提示词注入 模型敏感信息泄露 数据投毒 模型投毒 过度代理 向量嵌入错误 无界消费 输出越狱问题 对话模板问题 模型供应链问题	此类漏洞指在人工智能应用中，因未正确过滤输入的恶意指令或隐藏在被模型检索的文档中的恶意指令，导致人工智能模型无法正确识别执行指令或模型行为被误导或被操纵。	此漏洞类型参考了《OWASP Top 10 LLM 2025》和《Trustworthy and Responsible AI》等人工智能安全领域实践，用于人工智能领域相关漏洞分类。

附 录 I
（资料性）
漏洞分级兼容性说明

本文件漏洞分级继承了GB/T 30279-2020的“可利用性”“影响程度”“环境因素”三大核心维度，对GB/T 30279-2020中漏洞分级指标完全对应承接，并通过指标名称优化（如“访问路径”改“攻击路径”等）、指标维度细化（如“保密性”分“直接/间接影响”等）、新增指标（如“攻击复杂度”“防护能力”），实现了对原标准漏洞分级指标项的升级拓展，详细说明见表G.1。本文件保留了GB/T 30279-2020漏洞危害等级评估的基本逻辑，能够与GB/T 30279-2020漏洞分级深度兼容，在实践应用中不会与存量漏洞数据的分级结果产生明显冲突或矛盾。

表 I.1 漏洞分级指标变化

	GB/T 30279-2020标准指标项	本文件指标项		说明
可利用性	访问路径	攻击路径		名称优化
	触发要求	触发要求		保持不变
	权限要求	权限需求		名称优化
	交互条件	用户交互		名称优化
		攻击复杂度		新增指标
影响程度	保密性	保密性	直接影响	指标细化
			间接影响	
	完整性	完整性	直接影响	指标细化
			间接影响	
	可利用性	可利用性	直接影响	指标细化
			间接影响	
环境因素	被利用成本	利用成熟度		名称优化
	影响范围	潜在损失	业务潜在损失	指标细化
			社会潜在损失	
	修复难度	响应程度	修复成本	指标细化
			恢复难度	
		防护能力		新增指标

参考文献

[1] Common Vulnerability Scoring System v4.0: Specification Document
[2] Common Weakness Enumeration List Version 4.19
[3] Common Attack Pattern Enumerations and Classifications List Version 3.9
[4] CISA Stakeholder-Specific Vulnerability Categorization Guide 2022